



网络安全技术及应用

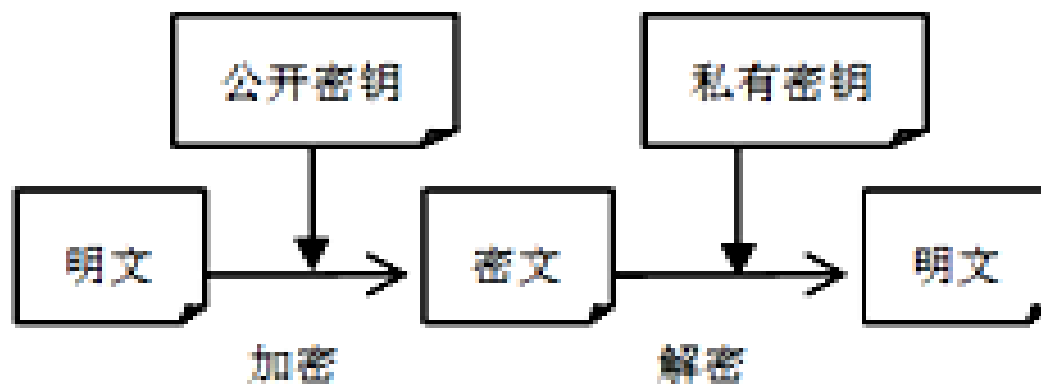
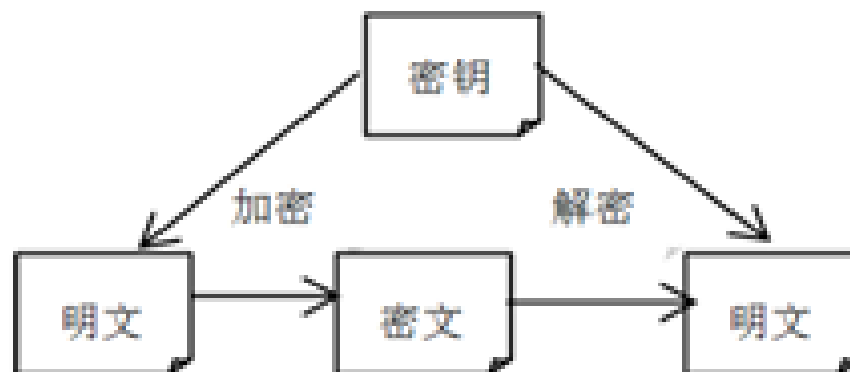
(第5版, 慕课微课版, 新形态)

贾铁军 何道敬 罗宜元 主编
古乐声 王威 张书台 副主编
王坚 陈国秦 参编

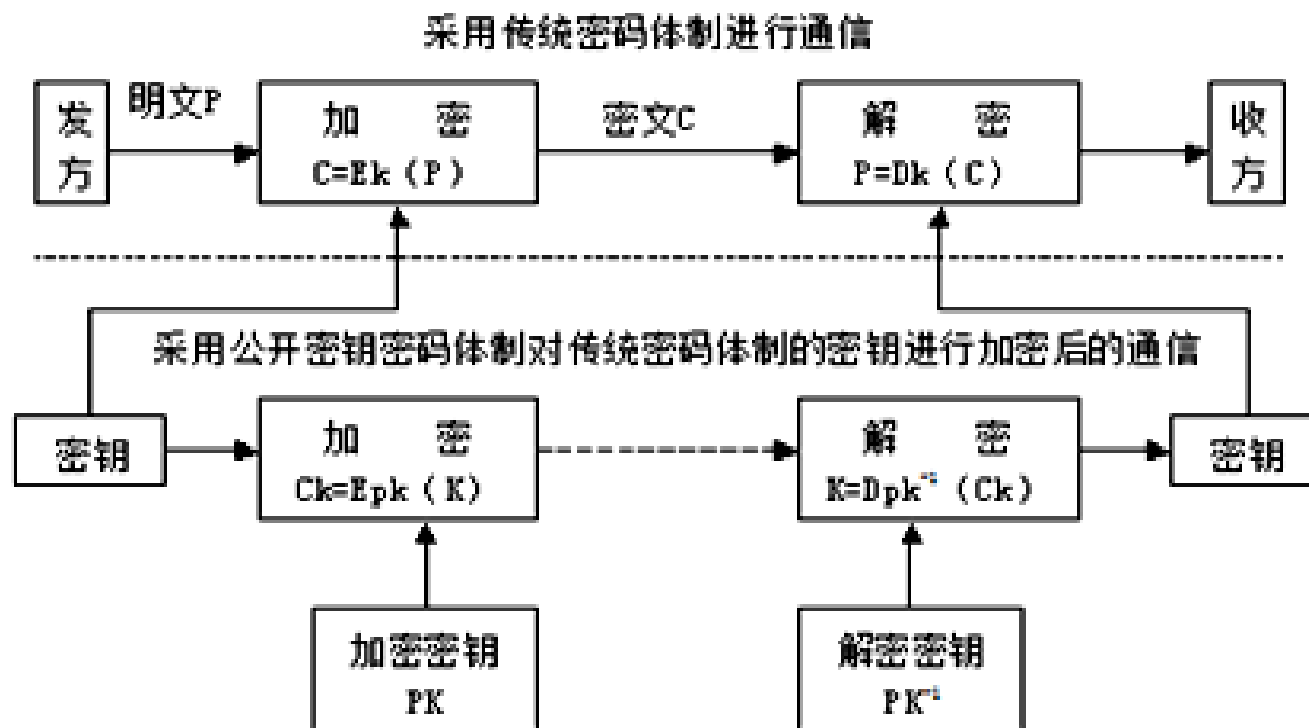
 机械工业出版社
CHINA MACHINE PRESS

第6章 身份认证与访问控制

回顾



回顾



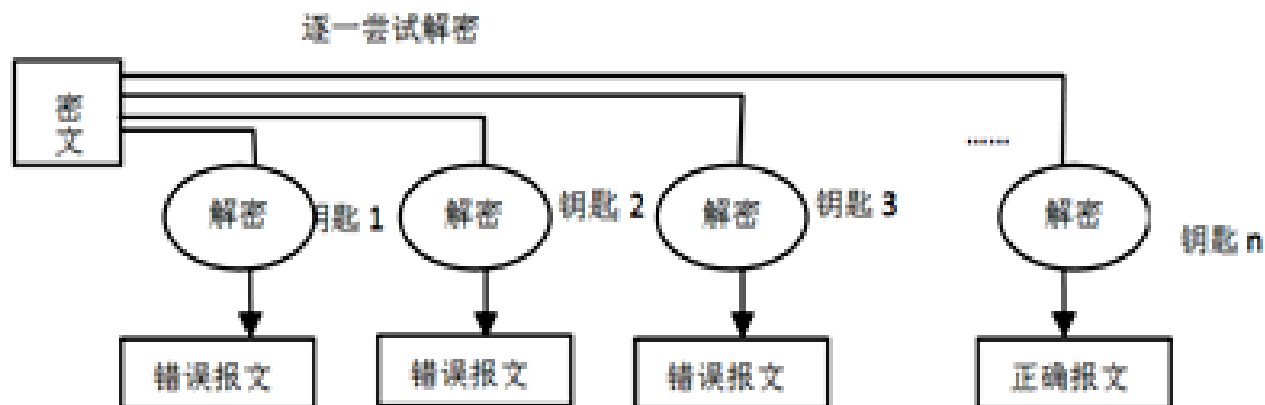
- 无条件安全性（一次一密）
- 计算安全性

回顾

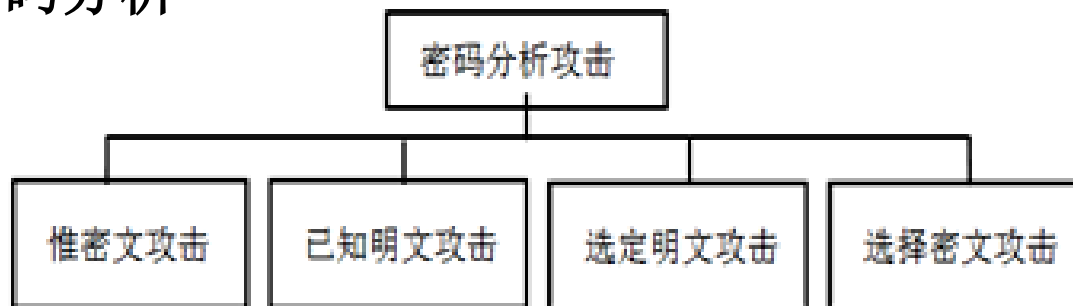
■ 密码破译方法

■ 穷举搜索密钥攻击

■ 例如，DES加密的密钥为56位。



■ 密码分析



回顾

■ 密钥管理

- KDC使用可信第三方来验证通信双方的真实性，产生会话密钥，并通过数字签名等手段分配密钥。
- Diffie-Hellman则不需KDC，通信发起方产生通信会话的私用密钥，并通过数字签名或零知识证明等方式安全传递通信密钥。
- 网络密钥主要有三种：
 - 会话密钥(Session Key)
 - 基本密钥(Basic Key)
 - 主密钥(Master Key)。

回顾

实用密码技术主要包括2种：

- **对称密码体制**

- 古典对称密码（凯撒密码、单表替换、多表替换）
- 现代分组密码（DES、3DES、AES）
- 现代流密码算法（RC4）
- 现代散列算法（MD5、SHA-1/2）

- **非对称密码体制（RSA）**

- **数字签名（综合应用散列算法和非对称密码体制）**

目 录

6.1

身份认证基础

6.2

身份认证技术与数字签名

6.3

访问控制技术

6.4

安全审计与电子证据

6.5

本章小结

6.6

实验6 配置IP访问控制列表



教学目标

📖 教学目标

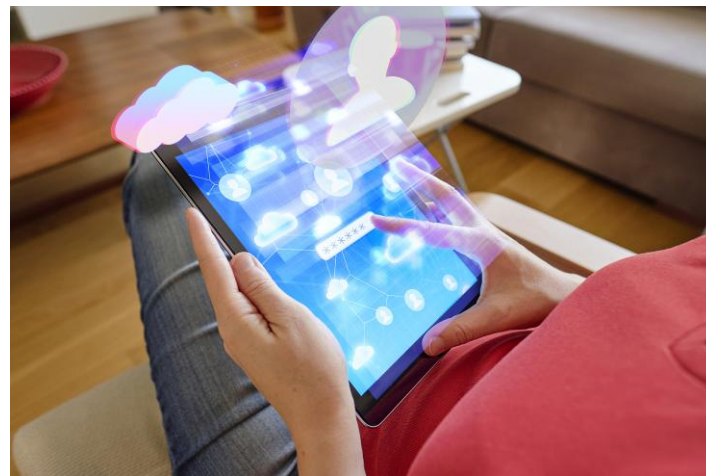
- 掌握身份认证的概念、类型和常用方法 **重点**
- 掌握数字签名的概念、方法和实现过程
- 掌握访问控制的概念、实现方法 and 安全策略 **重点**
- 理解安全审计的概念、类型、跟踪和实施
- 理解电子证据的类型和常用取证技术



6.1 身份认证基础

引导案例

据外媒报道，2020年Instagram、TikTok和YouTube均发生严重数据泄露事件，约2.35亿用户的数据被泄露，包含账户名称、电话、邮件、个人照片等关键信息，而这早已不是大型企业第一次发生数据泄露事件。纵观这些案例，可以发现数据大范围泄露的根本原因在于企业数字化转型中大量的业务上云，所有用户数据都被存储在云端，一旦网络安全稍有疏漏，就极易受到黑客攻击。其中，身份认证作为所有系统的入口，是首当其冲的环节。

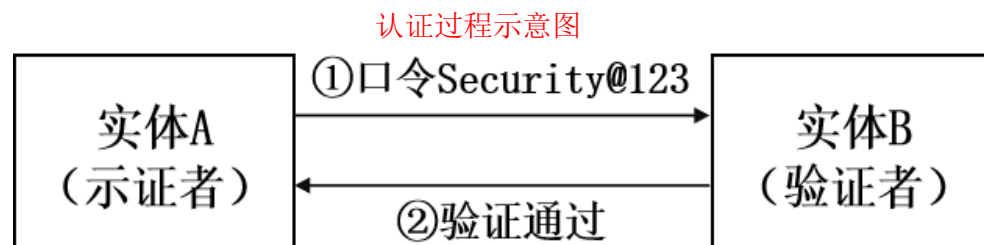


6.1 身份认证基础

6.1.1 认证概述

1. 认证技术的基本概念

认证(Authentication)是指对网络系统使用过程中的**主客体双方互相鉴别、确认身份**后，对其赋予恰当的**标志、标签、证书**等过程，也可以说是一个实体向另外一个实体证明其所声称的身份的过程，其中需要被证实的实体是**示证者（声称者）**，负责检查确认声称者的实体是**验证者**，双方按照一定的规则进行示证和验证。



实体**A**（示证者）向实体**B**（验证者）告知口令为**Security@123**，实体**B**验证该口令是正确的，则确认了实体**A**的身份。

6.1 身份认证基础

6.1.1 认证概述

在该认证过程中可能存在第三方**攻击者**，他可以窃听并伪装示证者骗取验证者的信任。因此，认证过程在必要时也会有第四方，即可**信者**，他的作用是参与调节纠纷。

按照认证过程中鉴别双方参与角色及所依赖的外部条件认证类型可分为单向认证、双向认证和第三方认证。



6.1 身份认证基础

2. 认证的类型

1) 单向认证。在认证过程中，验证者对示证者进行单方面的鉴别，而示证者不需要识别验证者的身份。实现单向认证的技术方法通常有2种，基于共享秘密和基于挑战响应。

2) 双向认证。双方在网上通信时，双方互相确认身份，参与认证的实体双方互为验证者。其认证过程的各方都与上述单向认证过程相同。在网络服务认证过程中，双向认证要求服务方和客户方互相认证，客户方也认证服务方，这样就解决了服务器的真假识别安全问题。

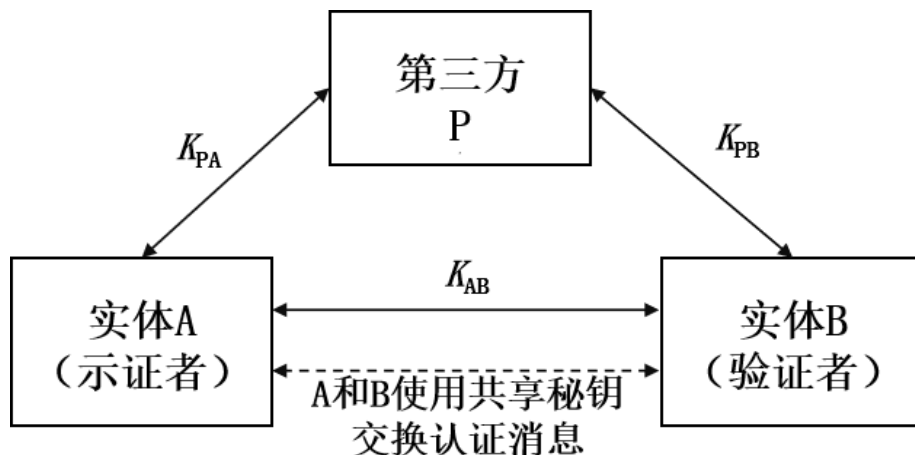


6.1 身份认证基础

2. 认证的类型

3) **第三方认证**。两个实体在鉴别过程中通过可信的第三方来实现。可信的第三方简称**TTP** (Trusted Third Party)。如图所示，第三方与每个认证的实体共享秘密，示证者和验证者分别与它共享密钥 K_{PA} 、 K_{PB} 。当示证者发起认证请求时，向可信第三方申请获取示证者和验证者的密钥 K_{AB} ，然后示证者和验证者使用 K_{AB} 加密保护双方的认证消息。

第三方认证过程示意图



6.1 身份认证基础

6.1.2 身份认证概述

1. 身份认证的基本概念

身份认证(Identity Authentication)，是网络系统的用户在进入系统或访问不同保护级别的系统资源时，系统确认验证用户身份真实、合法和唯一的过程，即系统对用户身份的识别和验证过程。

通常，身份认证基本方法有三种：

你知道什么？你
有什么？你是谁？

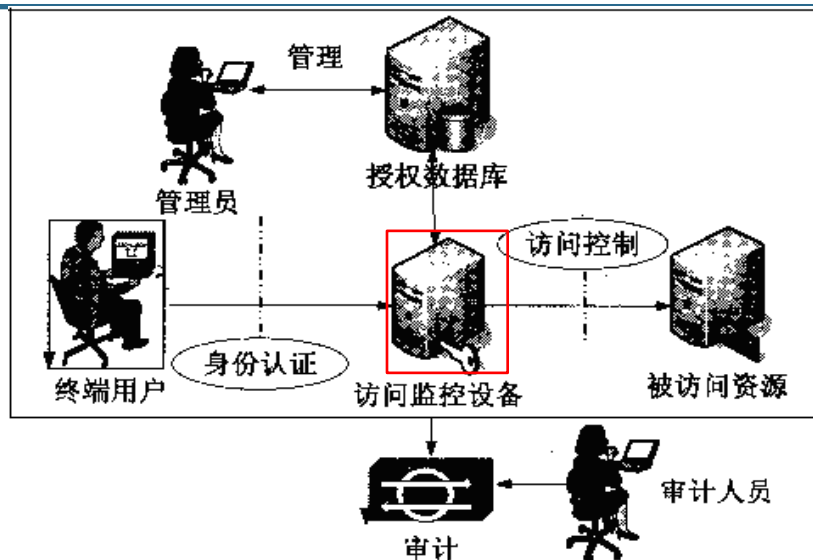
- 1) 用户所知道的事物，如口令、密码等。
- 2) 用户拥有的物品，如身份证、智能卡(如信用卡)、**USB Key**
- 3) 用户所具有的生物特征，如指纹、虹膜、视网膜、声纹、笔迹、**DNA**、人脸信息等。

6.1 身份认证技术概述

6.1.2 身份认证概述

2. 身份认证的作用

身份认证与鉴别是网络安全的第一道防线，对信息系统的安全有着重要意义。可以确保用户身份的真实、合法和唯一性，可以防止非法人员进入系统，通过各种违法操作获取不正当利益、非法访问受控信息、恶意破坏系统数据的完整性等情况的发生，严防“病从口入”关口。访问控制和审计系统都依赖于身份认证系统提供的“认证信息”鉴别和审计，如图所示。



身份认证和访问控制过程

6.1 身份认证技术概述

讨论思考：

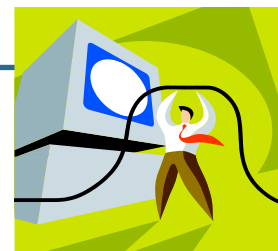
- 1) 认证从参与认证过程的角色及所依赖的外部条件主要有哪些类型？
- 2) 什么是身份认证？身份认证的作用是什么？
- 3) 常用的身份认证方式有哪些？并举例说明。



6.2 身份认证技术与数字签名

在网络系统中，**身份认证机制**定义了参与认证的通信方在身份认证过程中所需要交换的消息的格式、消息发生的次序以及消息的语义，为网络中的各种资源提供安全保护。

认证机制与授权机制常结合在一起，通过认证的用户才可获得使用权限。**常用的认证机制有**：固定口令方式、一次性口令认证、双因素安全令牌、单点登入等。**按照其实现方式**主要有：口令认证技术、智能卡认证技术、生物特征认证技术、**Kerberos**认证技术等多种实现方法。



6.2 身份认证技术与数字签名

6.2.1 口令认证技术

1. 固定口令方式

也叫**静态密码认证**。是一种以检验用户设定的固定字符串进行系统认证的方式，是最简单的身份认证方式。所有用户的密码由用户自己设定或修改，只有用户本人知道。当通过网络访问网站资源时，系统要求输入用户名和密码。在账户和密码被确认后，计算机就认为操作者是合法的，用户便可访问授权的资源。

固定口令认证方式简单，易受攻击：

- 1) 网络数据流窃听（**Sniffer**）。
- 2) 认证信息截取/重放。
- 3) 字典攻击。
- 4) 穷举尝试（**Brute Force**）。
- 5) 窥探密码。
- 6) 社会工程攻击(冒充)。
- 7) 垃圾搜索。

密码保护卡

使用说明：

- 1、密保卡相当于是您手上的动态密码库，请务必妥善保管
- 2、密保卡由序列号和一组7×7的数字矩阵组成
- 3、使用前请登录官方帐号管理中心：[Account.changyou.com](#)绑定并开通服务。绑定后，每次登录游戏时需要填入密保卡矩阵中所对应的坐标数字，使登录游戏更加安全
- 4、为了更好的保障帐号安全，建议您每隔7天更换一次密保卡
- 5、客服服务热线：010-68821898

密保卡序列号 4000002370256509

	1	2	3	4	5	6	7
A	91	18	44	22	10	09	53
B	43	77	84	59	97	04	41
C	54	22	89	39	45	50	94
D	89	57	36	66	21	06	01
E	85	44	53	76	62	97	99
F	72	06	52	15	84	36	75
G	82	41	16	36	64	06	76

6.2 身份认证技术与数字签名

6.2.1 口令认证技术

2. 动态口令(一次性)认证

一次性口令 (One Time Password, OTP) 认证体制, 主要在登入过程中加入不确定因素, 使每次登入过程中传送的信息都不相同, 从而提高系统安全性。是目前应用最广的一种身份识别方式, 主要有动态短信密码和动态口令牌 (卡)两种方式, 口令一次一密。

一次性口令认证系统组成:

- (1) 生成不确定因子
- (2) 生成一次性口令。



6.2 身份认证技术与数字签名

6.2.1 口令认证技术

2.动态口令(一次性)认证

(1) 生成不确定因子

- **口令序列方式**：口令为一前后相关的单向序列，系统只记录第 N 个口令。用户以第 $N-1$ 个口令登入时，系统用单向算法得出第 N 个口令与所存的第 N 个口令是否匹配，可判断用户的合法性。由于 N 为有限个，用户登入 N 次后必须重新初始化口令序列。
- **挑战/回答方式**：每次用户请求登录系统时，服务器端将不确定因子发送给用户，称为一次挑战，而用户提交的口令是根据发送来的不确定因子，通过某种单向算法将口令和这个不确定因子混合计算后发送给系统，系统以同样的方法验算，即可验证用户身份。这里的算法可以采用单向散列函数算法，也可以采用对称加密算法，每次计算出的口令不相同。



6.2 身份认证技术与数字签名

6.2.1 口令认证技术

【云通讯】您使用的是云通讯短信模板，您的验证码是123456，请于1分钟内正确输入

2. 动态口令(一次性)认证

(1) 生成不确定因子

- **时间同步方式**：客户端和服务端以时间作为不确定因子，要求双方的时间是严格同步的，精确度可以控制在约定的范围内，比如双方的时间差不超过一秒钟。
- **事件同步方式**：客户端和服务端以单向序列的迭代值作为不确定因子，要求双方每次迭代值的大小相同。这种方式的实现代价比时间同步方式小得多，而且也不用向挑战应答方式那样多出挑战的交互，这种方式客户端以单向迭代作为挑战，迭代作为规则可以在客户端实现。

【云通讯】您使用的是云通讯短信模板，您的验证码是928940，请于1分钟内正确输入

6.2 身份认证技术与数字签名

6.2.1 口令认证技术

2. 动态口令(一次性)认证

(2) 生成一次性口令

- **硬件卡(Token Card)**。在具有计算功能的硬件卡上输入不确定因子，卡中集成的计算逻辑会对输入数据进行处理，并将结果反馈给用户作为一次性口令。基于硬件卡的一次性口令大多属于挑战/回答方式，一般配备有数字按键，便于不定因子的输入。
- **软件(Soft Token)**。与硬件卡基本原理类似，以软件代替其计算逻辑。软件口令生成方式功能及灵活性较高，某些软件还可限定用户登入的地点。



6.2 身份认证技术与数字签名

3. 双因素安全令牌 (Secure Key)

当前，以单纯密码的方式提供系统安全认证已无法满足需求，目前这种方法存在较多的安全隐患。一是账号口令的记置非常烦琐，网络中的每一个节点都需要配置；二是为了保证口令的安全性，必须经常更改口令，耗费大量的人力和时间。同时，系统各自为政，缺少授权和审计的功能，无法根据用户级别进行分级授权，也不能提供用户访问设备的详细审计信息。

安全令牌是重要的双因素认证方式。双因素安全令牌认证系统已经成为认证系统的主要手段。如 **E-Securer** 双因素安全令牌及认证系统。

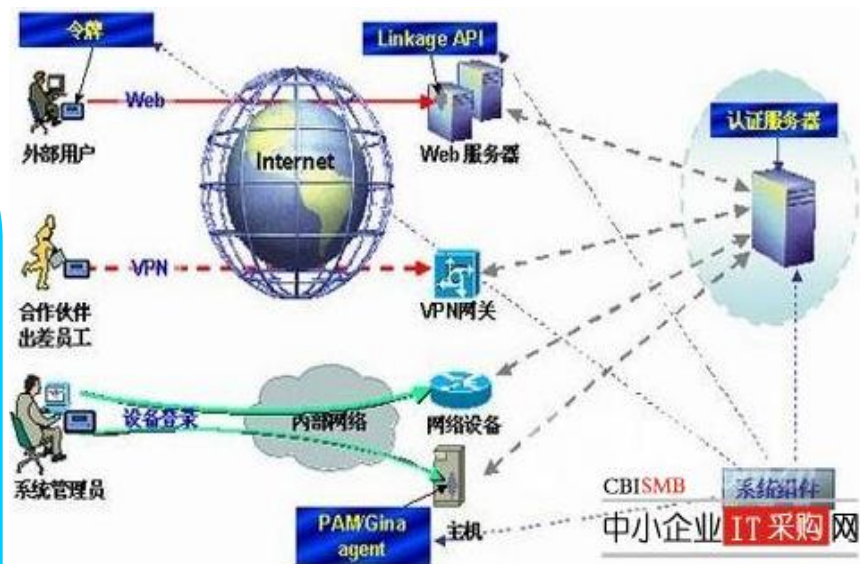
6.2 身份认证技术与数字签名

3. 双因素安全令牌 (Secure Key)

E-Securer安全身份认证系统是面向安全领域的**AAA**系统, 提供了**双因素身份认证**、**统一授权**、**集中审计**等功能, 可以为网络设备、**VPN**、主机系统、数据库系统、**WEB**服务器、应用服务系统等提供集中**身份认证和权限控制**。

*双因素身份认证系统组成

- 1) 身份认证服务器提供**数据存储**,**AAA**服务,管理等功能,是整个系统**核心**部分。
- 2) 双因素安全令牌(**Secure Key**)用于生成用户登录的动态口令, 采用加密算法及可靠设计, 可防止读取密码信息。
- 3) 认证代理安装在保护系统,系统通过认证代理向认证服务器发送认证请求, 从而保证被保护系统身份认证的安全。



RSA SecurID 双因素令牌



RSA双因素安全令牌



6.2 身份认证技术与数字签名

3. 双因素安全令牌 (Secure Key)

【案例 6-1】 MyHeritage 是一个家庭基因和 DNA 检测的网站，用户信息中不但存储有私人信息，甚至还有个人的 DNA 测试结果。2018 年 6 月，MyHeritage 发布公告称其网站服务器被攻击，攻击者从中截取了超过 9200 万名用户的信息，其中包含了电子邮件和 Hash 密码。不过 MyHeritage 表示，用户的账户是安全的，因为密码是使用每个用户唯一的加密密钥进行 Hash 处理的，为了彻底解决这种攻击隐患，最终网站启用了双因子身份验证（2FA）功能，即使黑客设法解密 Hash 密码，如果没有第二步的验证码，第一步的破解也将毫无用处。

6.2 身份认证技术与数字签名

6.2.2 智能卡技术

智能卡 (Smart Card) 是一种将具有加密、存储、处理能力的集成电路芯片嵌在塑料基片上而制成的卡片，是一种带有存储器和微处理器的**集成电路卡**，能够安全存储认证信息，并具有一定的计算能力。

智能卡认证根据用户所拥有的实物进行，发行时要经过**个人化(Personalization)**或**初始化(Initialization)**阶段，其具体内容因卡的种类和应用模式而不同。发卡机构根据系统设计要求将应用信息(如发行代码等)和持卡人的个人信息写入卡中，使该智能卡成为**持卡人的专有物**，并用于特定的应用模式。



6.2 身份认证技术与数字签名

6.2.2 智能卡技术

随着智能卡存储容量和处理功能的进一步加强，智能卡不仅广泛地应用于**电子货币、电子商务、劳动保障、医疗卫生**等对安全性要求高的系统中，也逐步扩大应用范围，如**二代身份证、公交一卡通、校园一卡通、电话/电视计费卡、电子门禁系统**等。同时，智能卡的安全涉及许多方面，如芯片的安全技术、卡片的安全制造技术、软件的安全技术及安全密码算法和安全可靠协议的设计。智能卡管理系统的安全设计也是其重要组成部分，对智能卡的管理包括制造、发行、使用、回收、丢失或损坏后的安全保障及补发等。此外，**智能卡的防复制、防伪造**等也是实际工作中要解决的重要课题。



6.2 身份认证技术与数字签名

6.2.3 生物特征认证技术

是指通过可测量的身体或行为等**生物特征信息**进行身份认证的技术。是利用人体唯一的、可靠的、稳定的生物特征，采用计算机技术和网络技术进行图像处理和模式识别，具有较强的安全性和可靠性。

- ❑ **身体特征**包括：指纹、掌形、虹膜、视网膜、人脸、**DNA**和手的血管等；
- ❑ **行为特征**包括：签名、语音、行走步态、击键特征、情境感知等。

人脸识别技术具体应用领域

应用领域	具体应用
公共安全	刑侦追逃、罪犯识别、边防安全
信息安全	计算机和网络的登录、文件的加密和解密
政府职能	电子政务、户籍管理、社会福利和保险
商业企业	电子商务、电子货币和支付、考勤、市场营销
场所进出	军事机要部门、金融机构的门禁控制和进出管理等

6.2 身份认证技术与数字签名

6.2.3 生物特征认证技术

【案例 6-2】 2014 年是我国人脸识别技术的转折点，人脸识别技术从理论走向了应用。2018 年，人脸识别技术进入了全面应用时期，在更多的领域解锁了更多应用，广东、江苏、浙江、河北等地在 2018 年的高考期间均启用了人脸识别系统；北京大学将人脸识别技术应用到了校园入园人员身份验证领域；北京市人社局也计划在市级公租房安装人脸识别系统，以预防公租房违规转租……“刷脸”时代正式到来。





6.2 身份认证技术与数字签名

6.2.4 Kerberos认证技术

1. 单点登入系统

在大型网络中通常设有多种应用服务器，如邮件服务器、**web** 服务器、文件服务器各类数据库服务器等。传统的基于用户名/口令的认证管理方式中，用户在每个系统中都可能有一组不同的用户名和口令，且用户的身份信息无法在各服务器间相互传递，当用户登录不同的系统时都必须输入相应的登录密码进行认证。另一方面，每台服务器还需要存储和维护用户登录密码，增加了系统管理的负担，也为网络安全留下了隐患，为此产生了单点登入系统。

6.2 身份认证技术与数字签名

6.2.4 Kerberos认证技术

1. 单点登入系统

单点登入（**Single Sign On, SSO**）也称**单次登入**，是在多个应用系统中，用户只需要登入一次就可访问所有相互信任的应用系统，是目前比较流行的企业业务整合的解决方案之一。

单点登入的优点体现在5个方面：

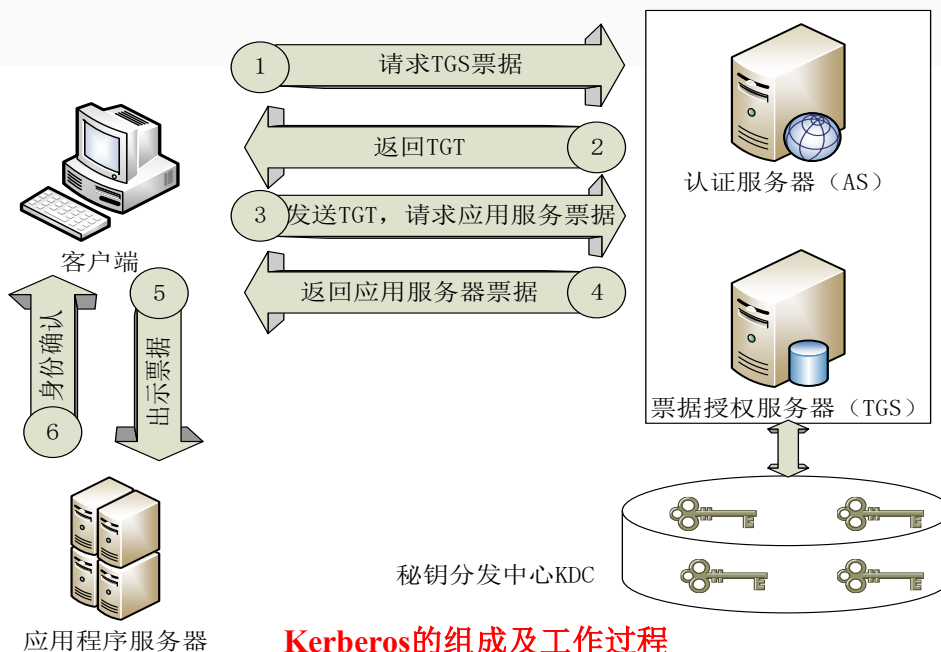
- 1) 管理简单。
- 2) 管理控制便捷。
- 3) 用户使用简捷。
- 4) 安全性更高。
- 5) 合并异构网络。



6.2 身份认证技术与数字签名

2.Kerberos认证技术

能够为用户提供安全的单点登入服务的协议中，最有代表性的是 **Kerberos协议**。Kerberos协议是美国麻省理工学院 Athena 计划的一部分，是一种基于对称密码算法的网络认证（鉴别）协议，其设计目标就是提供一种安全、可靠、透明、可伸缩的认证服务，其组成及工作过程如图 6所示。

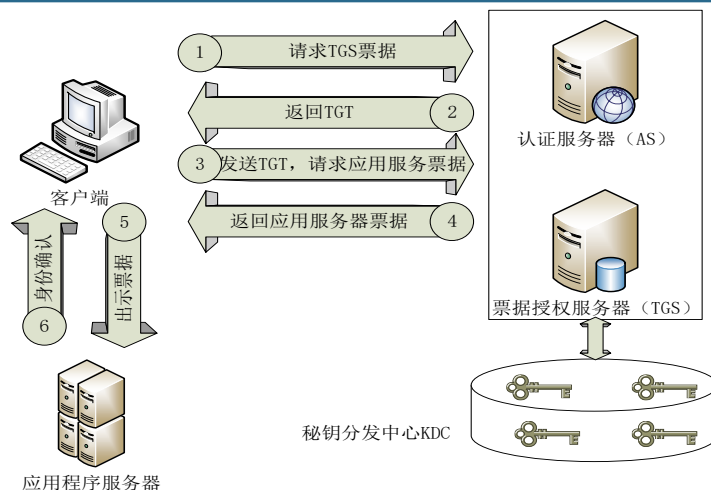


Kerberos的组成及工作过程

6.2 身份认证技术与数字签名

2.Kerberos认证技术

Kerberos 模型主要包括**客户端**、**服务器**和**密钥分发中心(Key Distributed Center, KDC)**3个部分，其中**KDC** 又包括**认证服务器(Authentication Server, AS)**和**票据授权服务器(Ticket-Granting Server, TGS)**两部分。**KDC** 是整个系统的核心部分，它保存所有用户和服务器的密钥，并提供身份验证服务以及密钥分发功能。也就是说，**Kerberos**知道每个人的密钥，故而它能产生消息，向一个实体证实另一个实体的身份。**Kerberos**还能产生会话密钥，只供一个客户机和一个服务器(或两个客户机之间)使用，会话密钥用来加密双方的通信消息，通信完毕，会话密钥即被销毁。



Kerberos的组成及工作过程

6.2 身份认证技术与数字签名

2.Kerberos认证过程

第一阶段：客户端与认证服务器 (AS) 交互

1.客户端发起请求：客户端将自己的用户名、IP 地址和时间戳发送到 AS，标识身份并防止重放攻击。

2.AS 检查用户是否存在：AS 在 AD 中查找用户是否存在于域中（例如白名单）。如果用户存在，AS 认为用户有效，继续下一步；否则，认证失败。

3. AS 向客户端返回两部分内容：（1）TGT（票据授予票据）：包含客户端信息、IP 地址和时间戳等，经过 TGS 的密钥加密，只有 TGS 能解密和读取其中的内容。（2）会话密钥 (CT_SK) 及其他信息：包括 CT_SK (client+TGS session key)、TGS 信息、TGT 有效时间和时间戳。此部分使用客户端密钥加密，客户端用自己的密钥解密以提取 CT_SK 和时间戳。

第一阶段结果：客户端成功获取了 TGT 和用于与 TGS 通信的会话密钥 CT_SK。

6.2 身份认证技术与数字签名

2.Kerberos认证过程

第二阶段：客户端与票据授予服务 (TGS) 交互

1.客户端验证 **AS** 响应的时间戳：客户端检查时间戳是否超过 **5** 分钟，避免伪造认证。验证通过后，客户端继续与 **TGS** 通信。

2. 客户端向 **TGS** 发起请求：请求内容分为三部分：（1）使用 **CT_SK** 加密的客户端信息、IP 地址和时间戳，用于 **TGS** 识别客户端身份。（2）客户端希望访问的服务（明文）。（3）**TGT**，由 **AS** 生成并加密（这个密钥只有 **KDC** 中的 **TGS** 服务知道，只有 **TGS** 能解密并读取 **TGT** 中的内容）

3. **TGS** 验证请求并生成服务票据 (**ST**):

TGS 解密 **TGT**：获取到用户信息和 **CT_SK**，并通过时间戳确认请求是否有效。

对比信息：**TGS** 使用 **CT_SK** 解密客户端发送的第一部分，并验证用户信息一致性，确保客户端身份真实。

生成响应：（1）使用服务端密钥加密的服务票据 **ST**，包含客户端信息、目标服务信息、**ST** 有效期、时间戳和会话密钥 **CS_SK**（**client-server session key**）（用于客户端和服务端通信）。（2）使用 **CT_SK** 加密的内容，包含 **CS_SK**、时间戳和 **ST** 有效期，客户端用 **CT_SK** 解密获取这些内容。

第二阶段结果：客户端成功获得服务票据 (**ST**) 和客户端-服务端会话密钥 **CS_SK**。

6.2 身份认证技术与数字签名

2.Kerberos认证过程

第三阶段：客户端与目标服务交互

1. 客户端向服务端发起请求：请求内容包括两部分：（1）使用 **CS_SK** 加密的客户端信息和时间戳。（2）使用目标服务的密钥加密的 **ST**（**TGS** 返回的**ST**，**ST**中包含 **CS_SK**），客户端无法解密。

2. 服务端验证客户端身份：

解密 **ST**：服务端使用自己的密钥解密 **ST**，获得客户端信息和会话密钥 **CS_SK**。

验证信息一致性：使用 **CS_SK** 解密客户端发送的第一部分内容，核对解密后的客户端信息是否与**ST**中一致，以确认客户端身份真实性。

3. 双向认证确认：服务端向客户端发送确认消息，使用 **CS_SK** 加密。客户端解密后确认服务端的真实性，从而完成认证。

第三阶段结果：客户端与服务端成功完成双向认证，基于 **CS_SK** 的安全通信通道建立。至此，第三阶段通信完成，到这里整个 **kerberos** 认证也就完成了，接下来客户端与服务端就能放心的进行通信了。

6.2 身份认证技术与数字签名

2.Kerberos认证过程

第一阶段：客户端与认证服务器 (AS) 交互

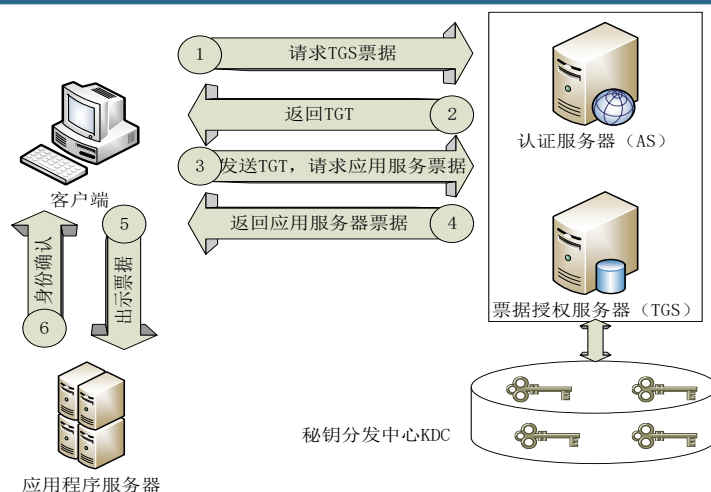
结果：客户端成功获取了 TGT 和用于与 TGS 通信的会话密钥 CT_SK

第二阶段：客户端与票据授予服务 (TGS) 交互

结果：客户端成功获得服务票据 (ST) 和客户端-服务端会话密钥 CS_SK

第三阶段：客户端与目标服务交互

结果：客户端与服务端成功完成双向认证，基于 CS_SK 的安全通信通道建立。



Kerberos的组成及工作过程

6.2 身份认证技术与数字签名

2.Kerberos认证技术

优点：可以显著减少用户密钥的密文暴露次数，从而减少攻击者对有关用户密钥的密文的积累。同时，Kerberos 认证过程具有单点登入的优点，当用户拿到 AS 的认证票据 TGT 并且该票据没有过期时，用户就可以使用该 TGT 通过 TGS 完成到任一服务器的认证而不必重新输入密码。

缺点：Kerberos 认证系统要求解决主机节点时间同步问题和抵御拒绝服务攻击。如果某台主机的时间被更改，那么这台主机就无法使用Kerberos 认证协议了，如果服务器的时间发生了错误，那么整个 Kerberos 认证系统将会瘫痪。尽管Kerberos 有不尽如人意的地方，但它仍然是一个比较好的安全认证协议。目前，Windows系统和Hadoop 都支持 Kerberos 认证。



6.2 身份认证技术与数字签名

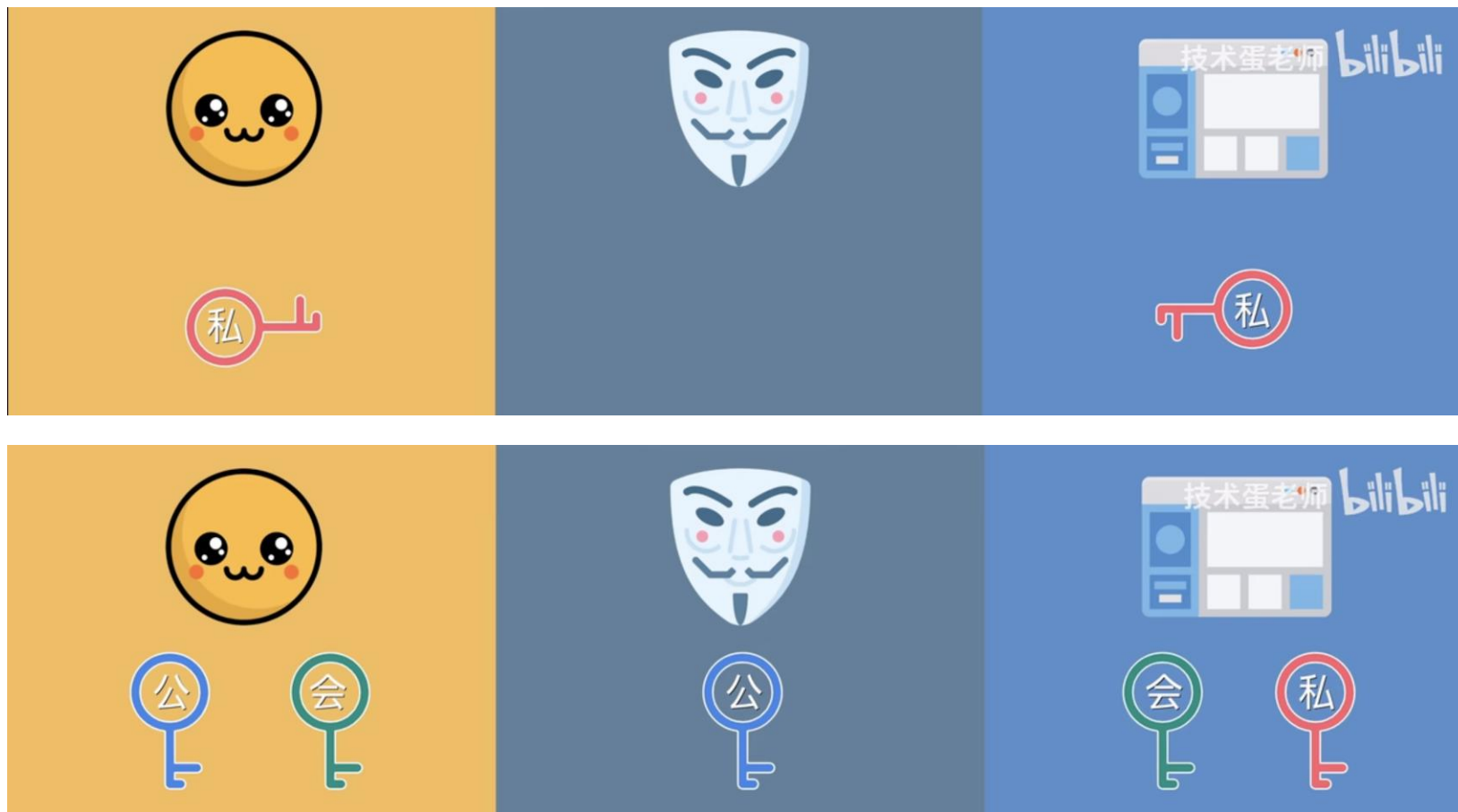
6.2.5 公钥基础设施 (PKI) 技术

公钥密码体制能够有效实现通信的保密性、完整性、不可否认性和身份认证，但实践中该体制面临公钥共享和分发的问题，即公钥的真实性和所有权问题。针对该问题，人们采用“公钥证书”的方法来解决，类似身份证、护照。公钥证书是将实体和一个公钥绑定，并让其他的实体能够验证这种绑定关系。为此，需要一个可信第三方来担保实体的身份，这个第三方称为认证机构，简称**CA(Certification Authority)**。**CA** 是国际认证机构的通称，负责颁发证书，证书中含有实体名、公钥以及实体的其他身份信息。

PKI(Public Key Infrastructure)就是有关创建、管理、存储、分发和撤销公钥证书所需要的硬件、软件、人员、策略和过程的安全服务设施。

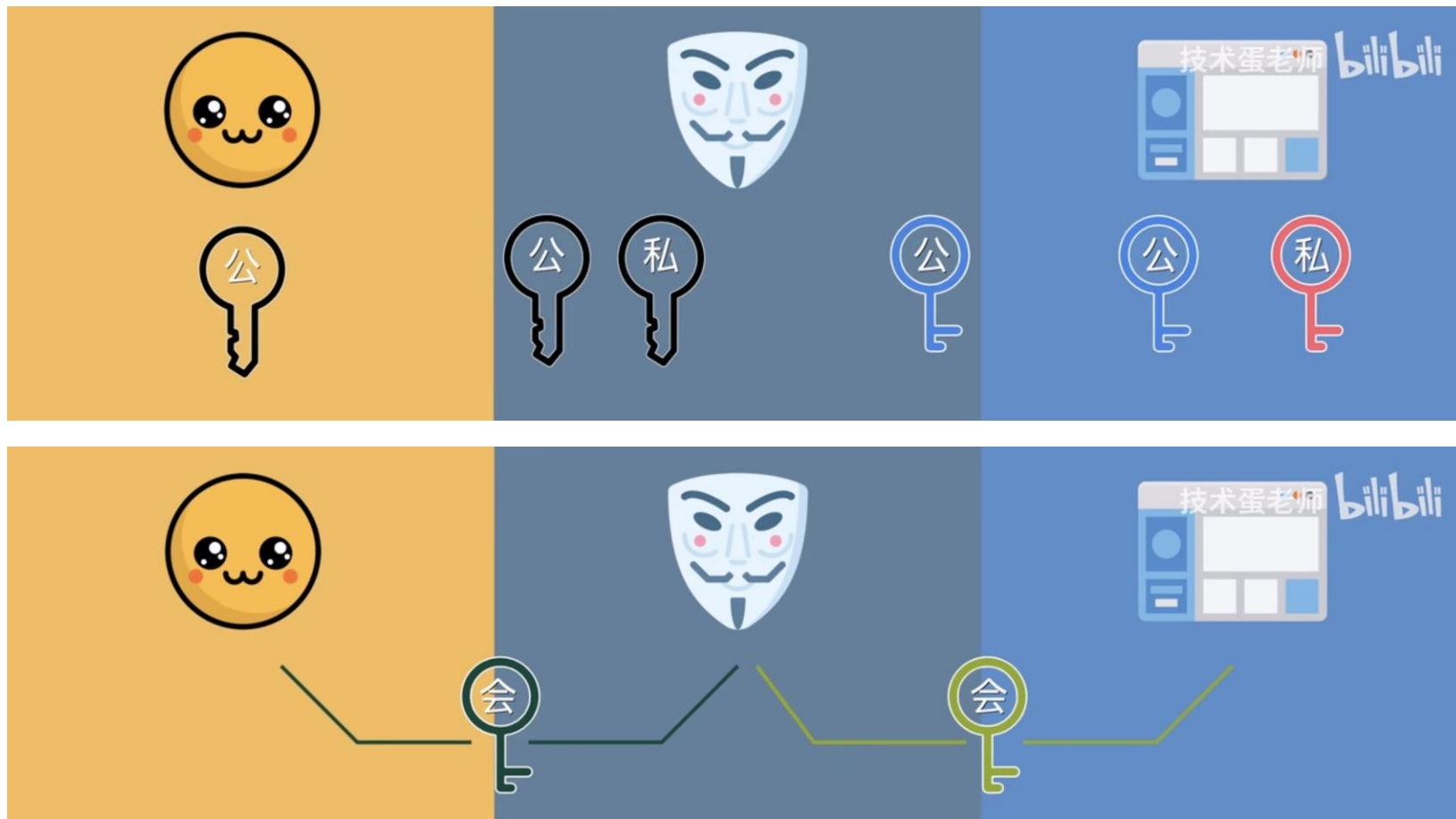
6.2 身份认证技术与数字签名

6.2.5 公钥基础设施（PKI）技术



6.2 身份认证技术与数字签名

6.2.5 公钥基础设施（PKI）技术



6.2 身份认证技术与数字签名

6.2.5 公钥基础设施 (PKI) 技术



技术蛋老师 bilibili

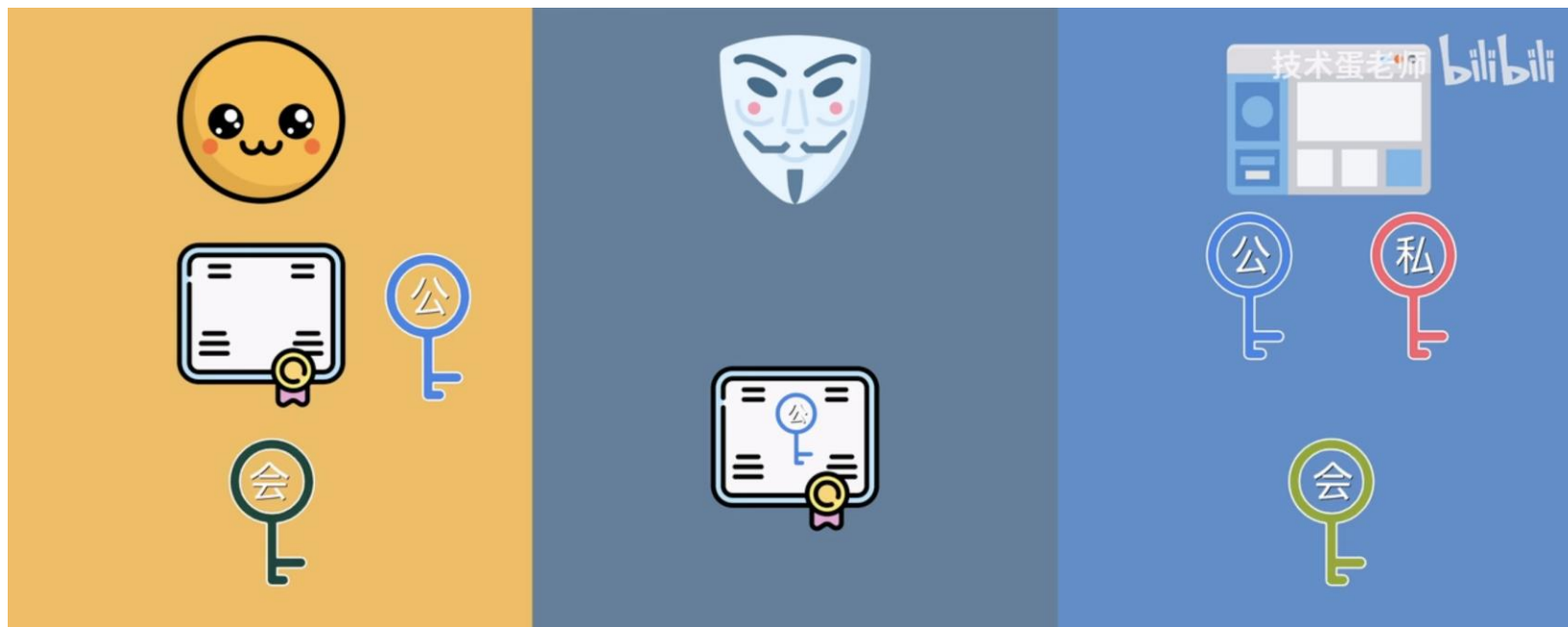


技术蛋老师 bilibili



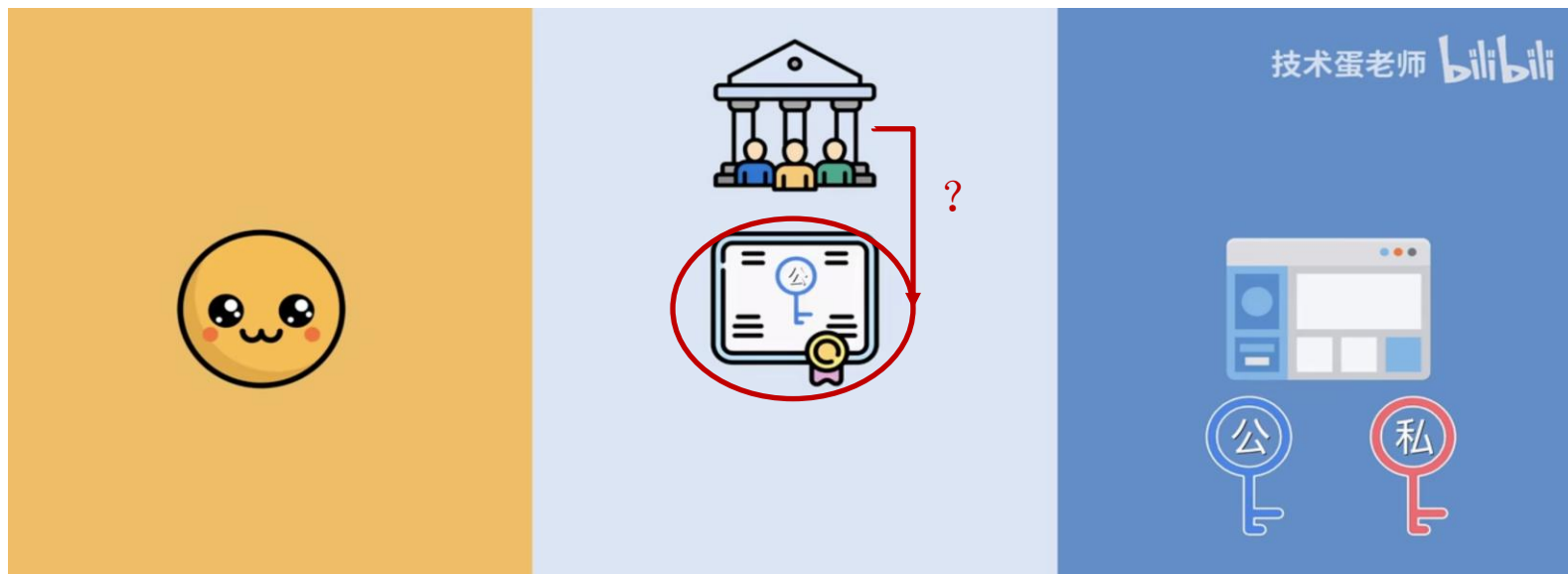
6.2 身份认证技术与数字签名

6.2.5 公钥基础设施（PKI）技术



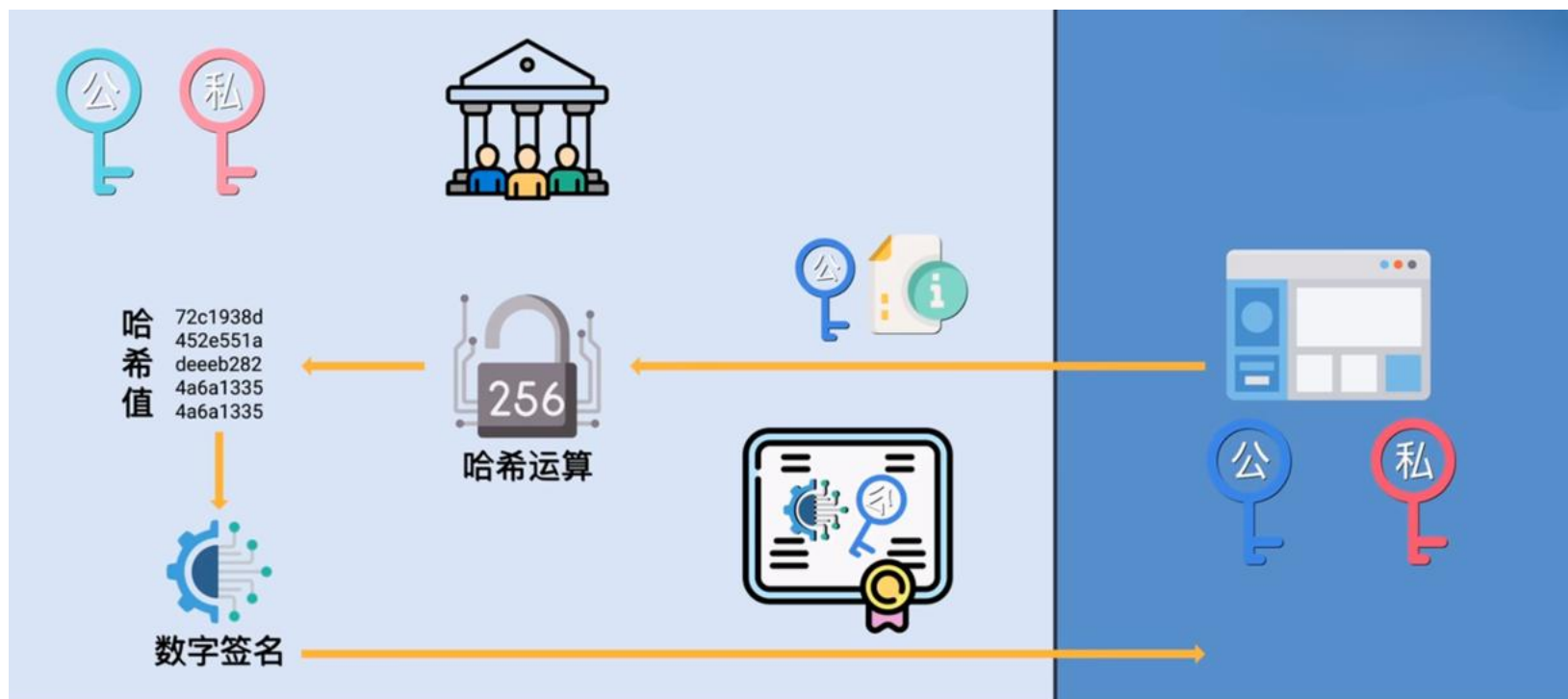
6.2 身份认证技术与数字签名

6.2.5 公钥基础设施（PKI）技术



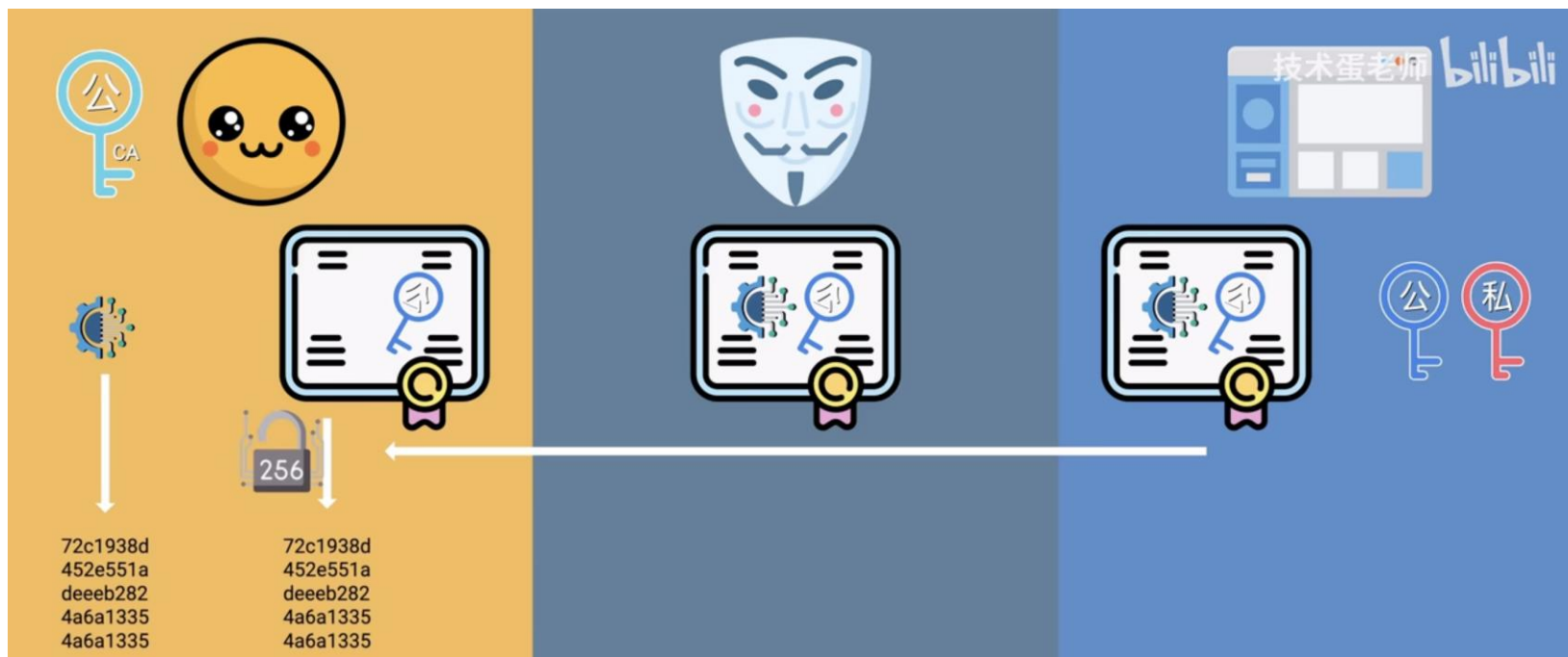
6.2 身份认证技术与数字签名

6.2.5 公钥基础设施（PKI）技术



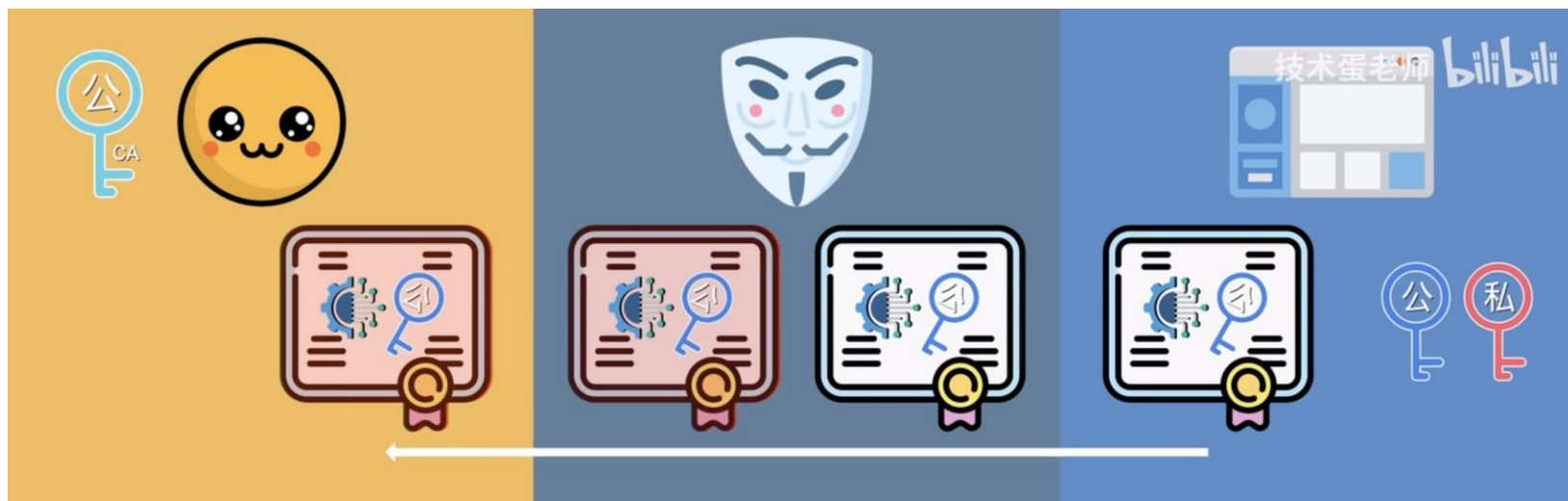
6.2 身份认证技术与数字签名

6.2.5 公钥基础设施（PKI）技术



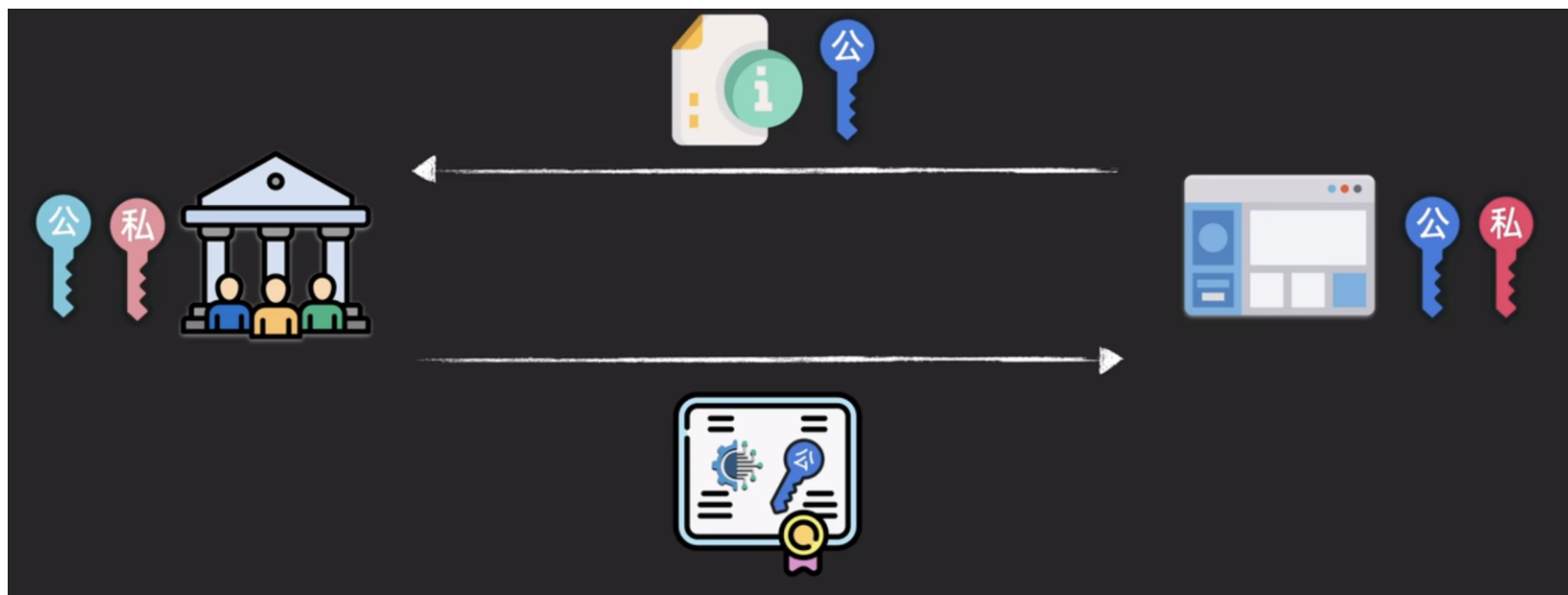
6.2 身份认证技术与数字签名

6.2.5 公钥基础设施（PKI）技术



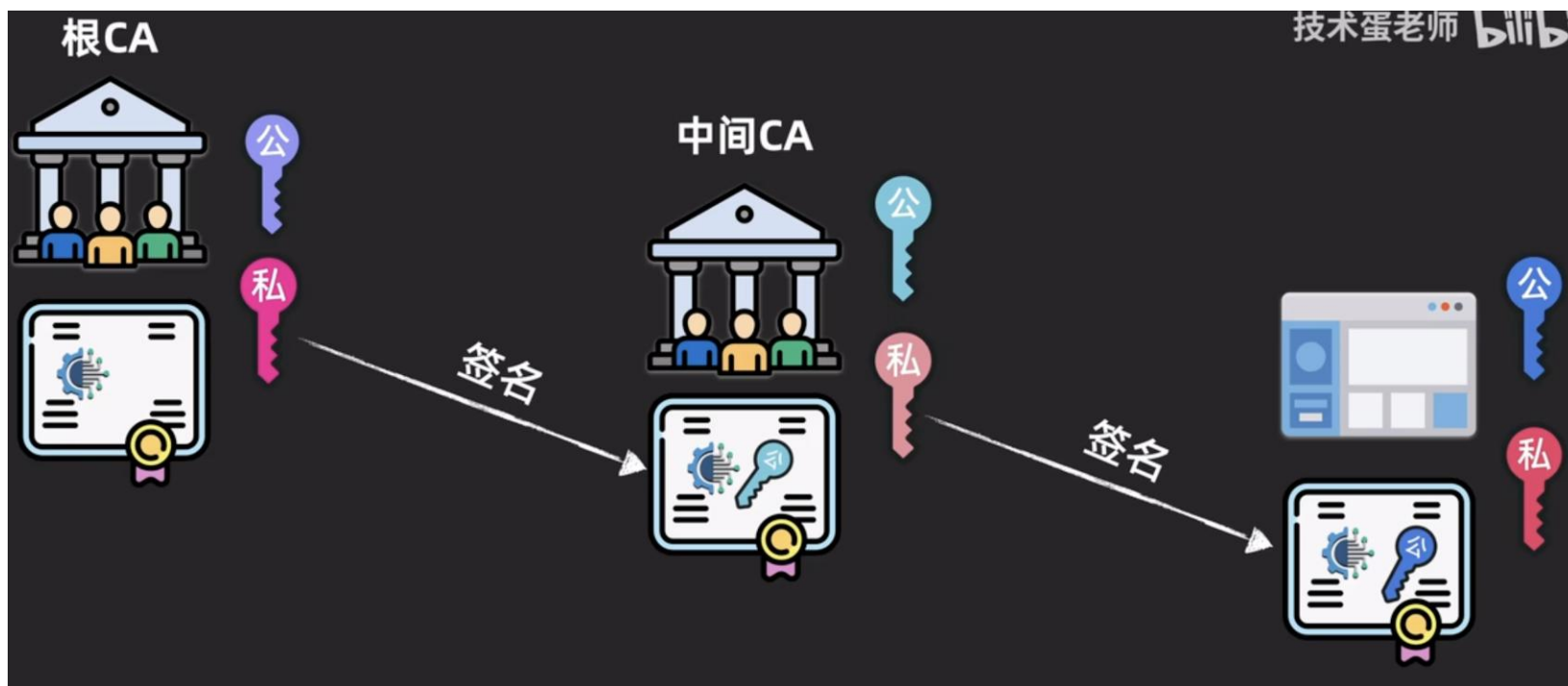
6.2 身份认证技术与数字签名

6.2.5 公钥基础设施（PKI）技术



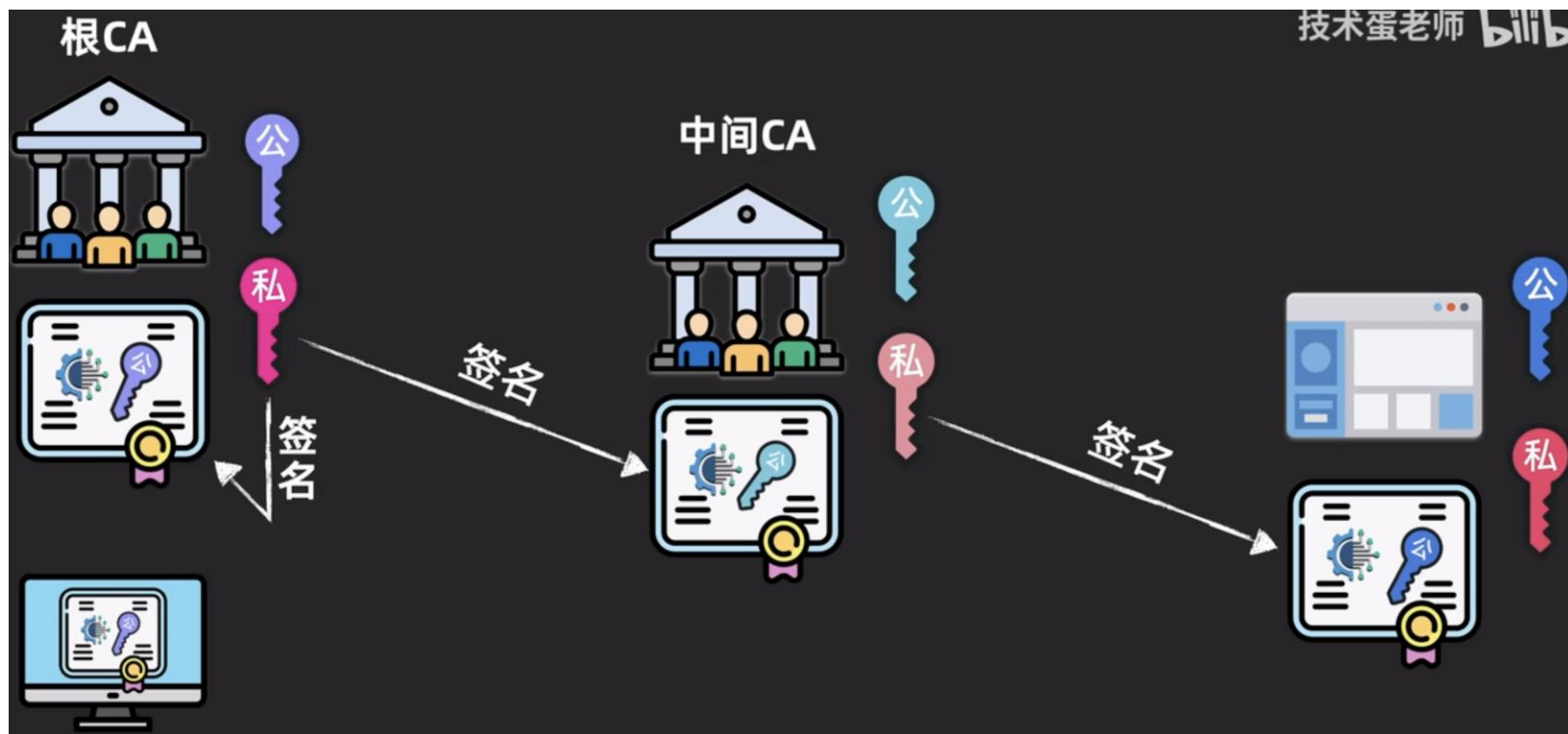
6.2 身份认证技术与数字签名

6.2.5 公钥基础设施（PKI）技术



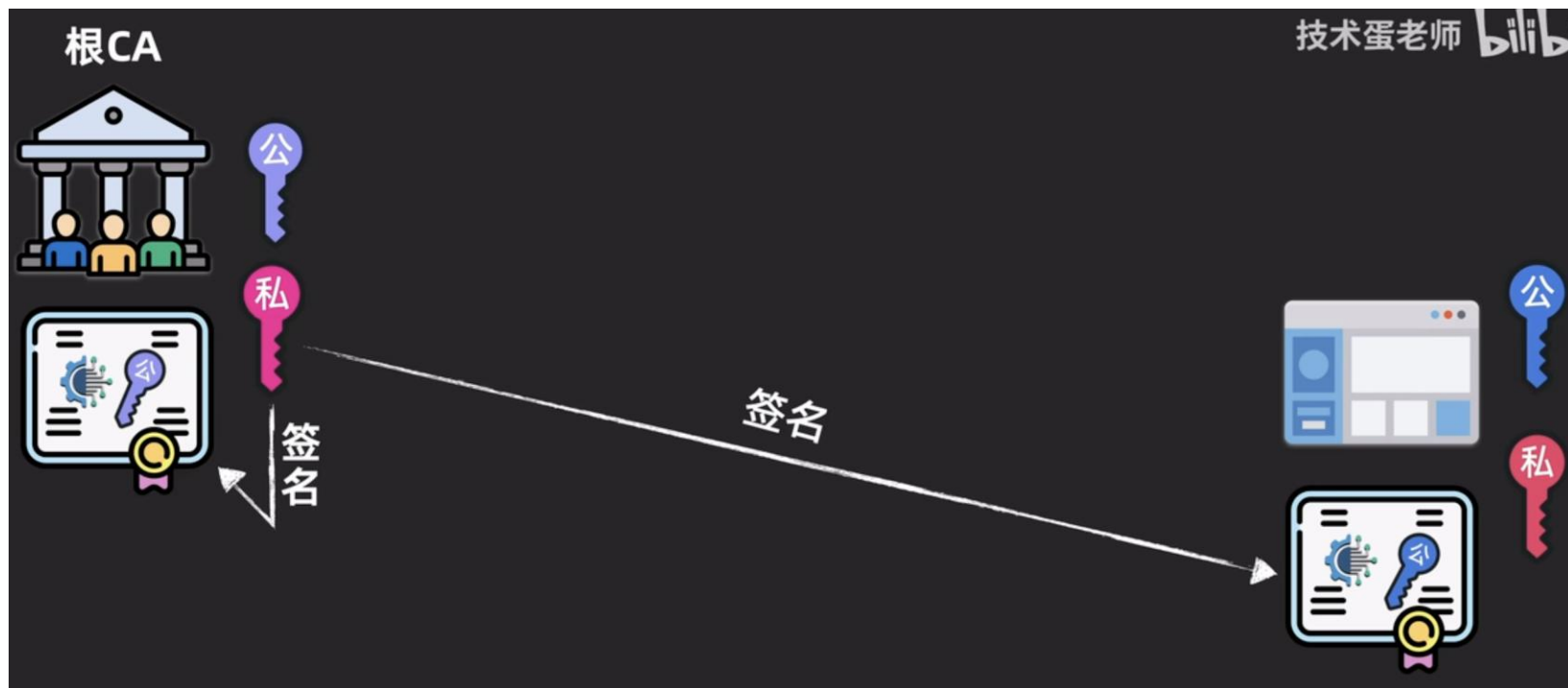
6.2 身份认证技术与数字签名

6.2.5 公钥基础设施（PKI）技术



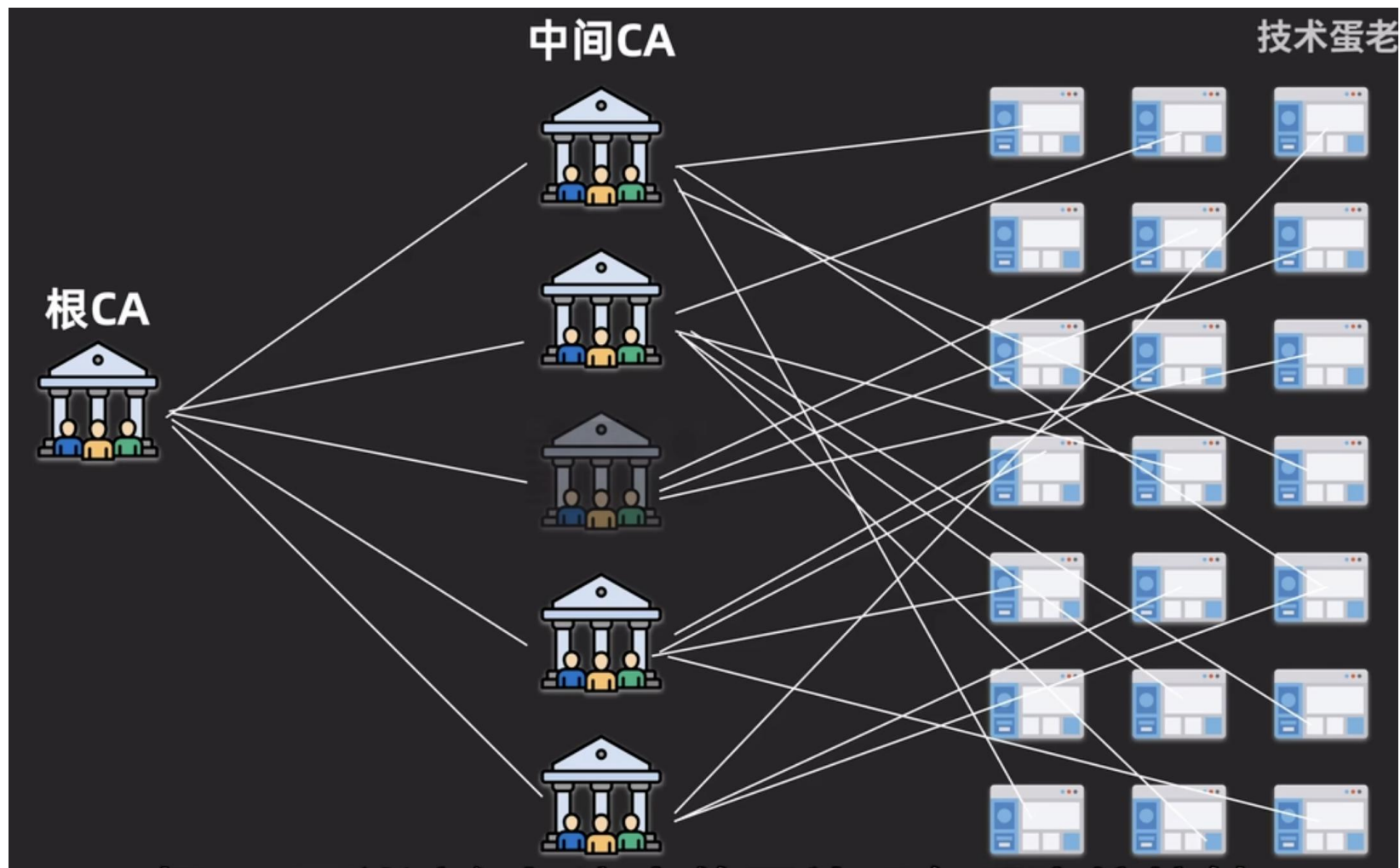
6.2 身份认证技术与数字签名

6.2.5 公钥基础设施（PKI）技术



6.2 身份认证技术与数字签名

6.2.5 公钥基础设施（PKI）技术

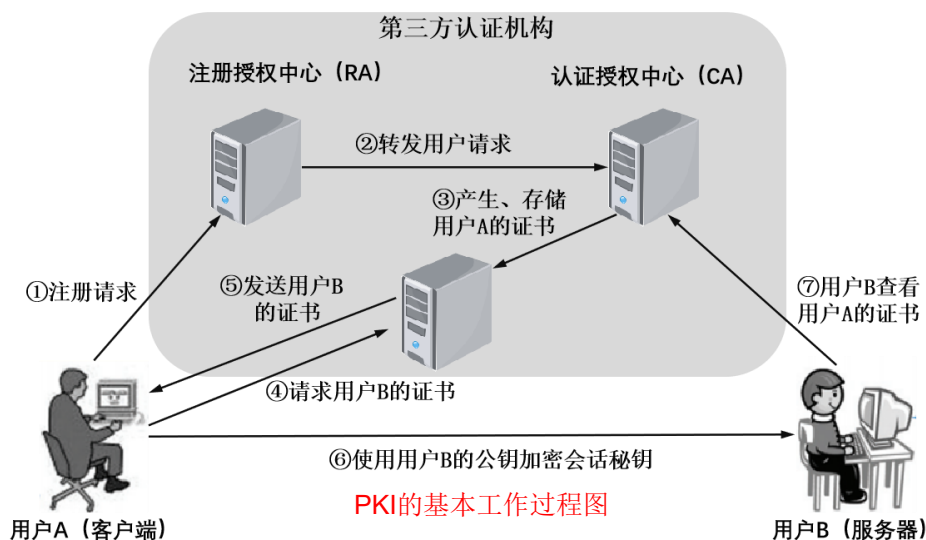


6.2 身份认证技术与数字签名

6.2.5 公钥基础设施 (PKI) 技术

PKI提供了一种系统化的、可扩展的、统一的、容易控制的公钥分发方法，其本质就是实现大规模网络中的公钥分发问题，建立大规模网络中的信任基础。基于 PKI 的主要安全服务有身份认证、完整性保护、数字签名、会话加密管理、密钥恢复。

一般来说，PKI涉及多个实体之间的协商和操作，主要实体包括注册授权中心RA(Registration Authority)、认证授权中心CA(Certification Authority)和数字证书库 (Digital Certificate Library)。

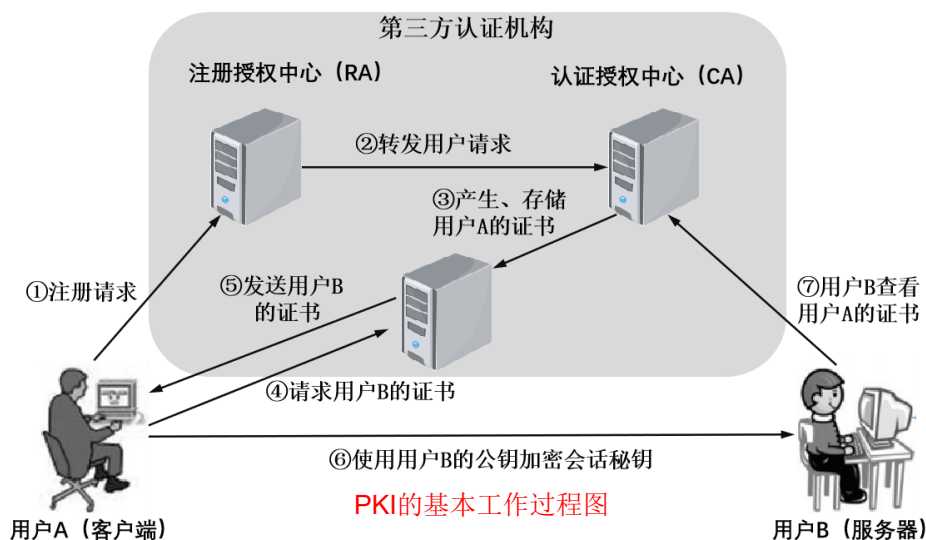


6.2 身份认证技术与数字签名

6.2.5 公钥基础设施 (PKI) 技术

PKI提供了一种系统化的、可扩展的、统一的、容易控制的公钥分发方法，其本质就是实现大规模网络中的公钥分发问题，建立大规模网络中的信任基础。基于 PKI 的主要安全服务有身份认证、完整性保护、数字签名、会话加密管理、密钥恢复。

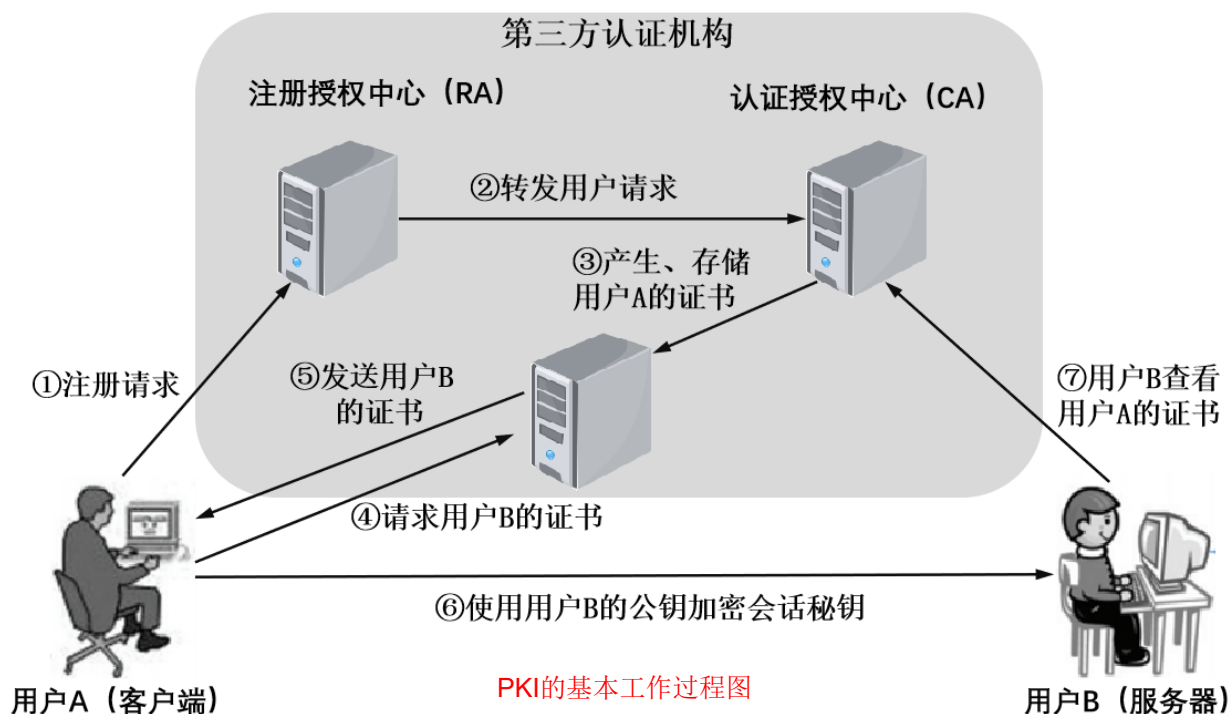
一般来说，PKI涉及多个实体之间的协商和操作，主要实体包括注册授权中心RA(Registration Authority)、认证授权中心CA(Certification Authority)和数字证书库 (Digital Certificate Library)。



6.2 身份认证技术与数字签名

6.2.5 公钥基础设施 (PKI) 技术

注册授权中心(RA)是负责证书注册任务的可信机构(或服务器), 对于第一次使用 **PKI**进行认证的用户, **RA**负责建立和确认用户身份。**RA**不负责证书的事务, 它只作为用户和 **CA** 的中间人。当需要生成证书的时候, 用户向 **RA** 发送请求, **RA** 将请求转发给 **CA**。



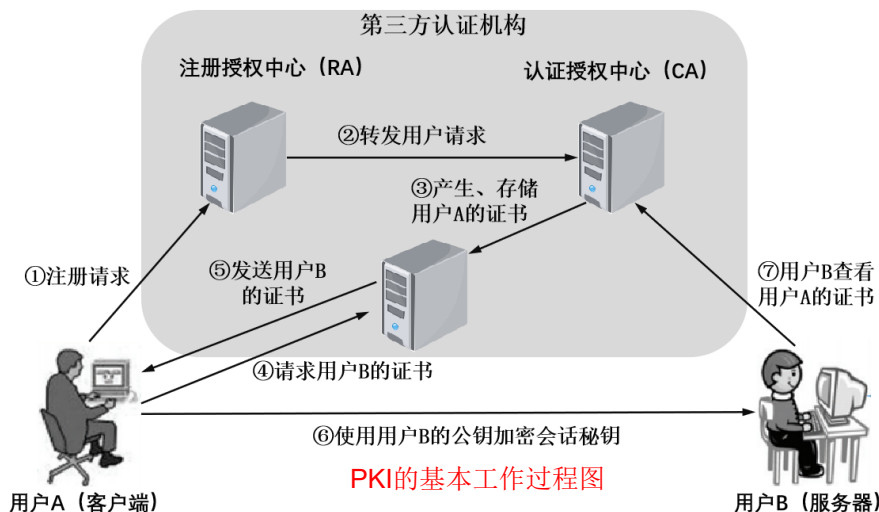
6.2 身份认证技术与数字签名

6.2.5 公钥基础设施 (PKI) 技术

认证授权中心(CA)用于审查证书持有者身份的合法性，并签发管理证书，以防止证书被伪造或篡改。认证机构如同一个权威可信的中间人，可核实交易各方身份，负责电子证书的发放和管理。每个机构或个人上网用户都要有各自的网络身份证作为唯一识别。

CA的主要职能体现在3个方面：

- (1) 管理和维护客户的证书和证书作废表 (CRL) 。
- (2) 维护整个认证过程的安全。
- (3) 提供安全审计的依据。



6.2 身份认证技术与数字签名

证书的类型与作用

证书名称	证书类型	主要功能描述
个人证书	个人证书	个人网上交易、网上支付、电子邮件等相关操作
单位证书	单位身份证书	用于企事业单位网上交易、网上支付等
	Email 证书	用于企事业单位内安全电子邮件通信
	部门证书	用于企事业单位内某个部门的身份认证
服务器证书	企业证书	用于服务器、安全站点认证等
代码签名证书	个人证书	用于个人软件开发者对其软件的签名
	企业证书	用于软件开发企业对其软件的签名

注：数字证书标准有：X.509证书、简单PKI证书、PGP证书和属性证书。

6.2 身份认证技术与数字签名

PKI的认证围绕数字证书进行，**数字证书**的内容：

1.**主体信息**，数字证书中包含了证书持有者的主体信息，通常包括姓名、电子邮件地址、组织单位等。

2.**公钥信息**，证书中包含了证书持有者的公钥，这是用于加密和解密信息的关键。

3.**签发者信息**，证书中包含了签发者的信息，即证书颁发机构(CA)的名称和公钥。

4.**证书序列号**，每个数字证书都有一个唯一的序列号，用于标识该证书的唯一性。

5.**有效期限**，数字证书包含了证书的有效期限，即证书的开始和结束日期，证书在有效期内才能被信任使用。

6.**数字签名**，数字证书中包含了CA对证书内容的数字签名，用于验证证书的真实性和完整性。

7.**扩展信息**，数字证书还可以包含一些扩展信息，比如证书用途、颁发者的信息等。

作用：**身份认证、保证数据完整性、保障信息的保密性。**

假数字证书？假认证授权中心CA？





6.2 身份认证技术与数字签名

6.2.6 数字签名

1. 数字签名的概念

数字签名（Digital Signature）又称公钥数字签名或电子签章，是以电子形式存储嵌入于文件/信息中/以附件或逻辑关联数据，用于辨识数据签署人身份，表明签署人对数据中所包含信息的认可，也用于保证信息来源的真实性、数据传输的完整性和防抵赖性。

在电子银行、证券和电子商务等方面应用非常广泛，如汇款、转账、订货、票据、股票成交等，用户以电子邮件等方式，使用个人私有密钥加密数据后，发送给接收者。接收者用发送者的公钥解密数据就可确定数据源。



6.2 身份认证技术与数字签名

6.2.6 数字签名

1. 数字签名的概念

《中华人民共和国电子签名法》中**数字签名**定义为：通过某种密码运算生成一系列符号及代码组成电子密码进行签名，**来代替**书写签名或印章，对于这种电子式的签名还可进行技术验证。采用规范化的程序和科学化的方法，用于鉴定签名人的身份以及对一项电子数据内容的认可，还可验证文件的原文在传输中有无变动，确保传输电子文件的完整性、真实性和不可抵赖性。

ISO 7498-2标准中定义数字签名为：附加在数据单元上的一些数据，或是对数据单元所做的密码变换，这种数据和变换允许数据单元的接收者用以确认数据单元来源和完整性，并保护数据，防止被人进行伪造。

6.2 身份认证技术与数字签名

6.2.6 数字签名

2. 数字签名的方法和功能

实现数字签名的技术手段有多种，主要方法：

- ①基于PKI的公钥密码技术的数字签名；
- ②用一个以生物特征统计学为基础的识别标识，如手书签名和图章的电子图像的模式识别；
- ③手印、声音印记或视网膜扫描的识别；
- ④一个让收件人能识别发件人身份的密码代号、密码或个人识别码PIN；
- ⑤基于量子计算机等。

比较成熟的、使用方便具有可操作性的、在世界先进国家和普遍使用电子签名技术还是基于PKI的数字签名技术。



6.2 身份认证技术与数字签名

6.2.6 数字签名的种类

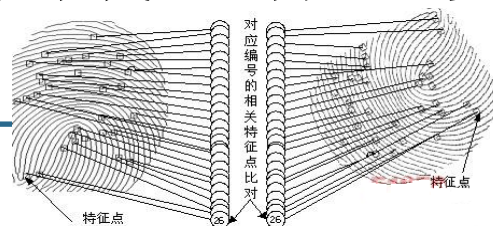
1. 手写签名或图章识别

将**手写签名或印章**作为**图像**,扫描后在数据库中加以存储,当验证此人的手写签名或盖印时,也用光扫描输入,并将原数据库中的对应图像调出,用模式识别方法对两者进行比对,以确认该签名或印章的真伪。



2. 生物识别技术

生物识别技术是利用人体生物特征进行身份认证的一种技术。**生物特征**是一个人的唯一表征,可以测量、自动识别和验证。**生物识别系统**对生物特征进行取样,提取其唯一的特征进行数字化处理,转换成数字代码,并进一步将这些代码组成特征模板存于数据库中。



6.2 认证系统与数字签名

6.2.2 数字签名的种类

3. 密码、密码代号或个人识别码

主要指用一种传统的对称密钥加/解密的身份识别和签名方法。甲方需要乙方签名一份电子文件，甲方可产生一个随机码传送给乙方，乙方用事先双方约定好的对称密钥加密该随机码和电子文件回送给甲方，甲方用同样的对称密钥解密后得到电文并核对随机码，如随机码核对正确，甲方即可认为该电文来自乙方。

4. 基于量子计算机(文件)

基于量子力学的计算机被称作量子计算机，是以量子力学原理直接进行计算的计算机。比传统的图灵计算机具有更强大的功能，计算速度要比现代的计算机快几亿倍。

5. 基于PKI的电子签名

基于PKI的电子签名被称作数字签名。有人称“电子签章”就是“数字签名”，其实这是一般性说法，数字签名只是电子签名的一种特定形式。

6.2 身份认证技术与数字签名

6.2.6 数字签名

2. 数字签名的方法和功能

数字签名算法组成主要有2部分：签名算法和验证算法。签名者可使用一个秘密的签名算法签一个消息，所得的签名可通过一个公开的验证算法来验证。当给定一个签名后，验证算法将对签名的真实性进行判断。目前，数字签名算法很多，如**RSA** 数字签名算法、**ElGamal** 数字签名算法、美国的数字签名标准/算法(**DSS/DSA**)、椭圆曲线数字签名算法和有限自动机数字签名算法等。

功能：保证信息传输的完整性、发送者的身份认证、防止交易中的抵赖行为发生。数字签名技术是将摘要信息用发送者的私钥加密，与原文一起传送给接收者。

最终目的是实现6种安全保障功能：

- (1) 必须可信。(2) 无法抵赖。(3) 不可伪造。
- (4) 不能重用。(5) 不许变更。(6) 处理快、应用广。

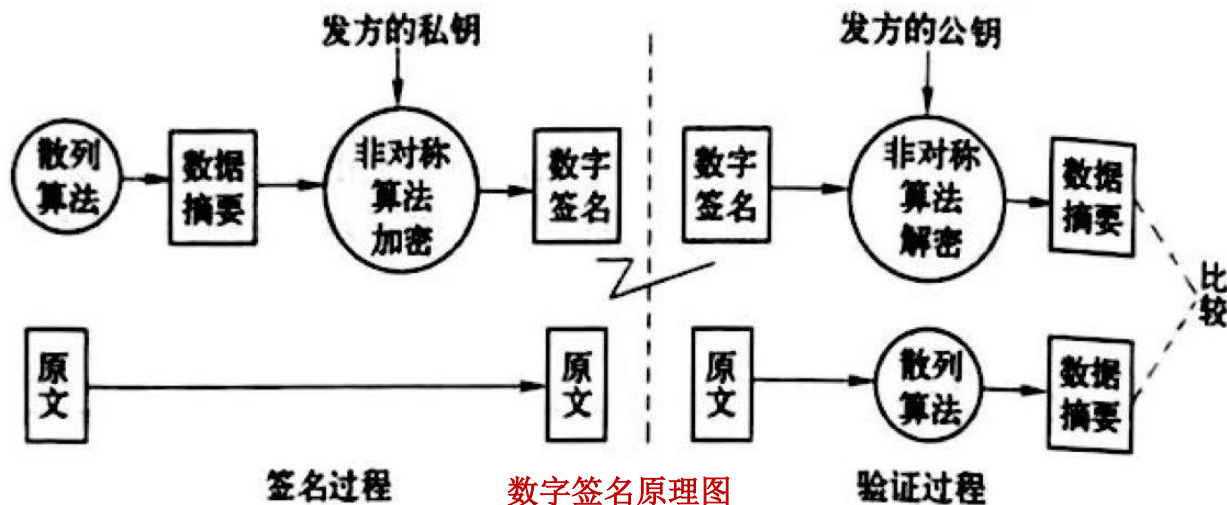
6.2 身份认证技术与数字签名

6.2.6 数字签名

3. 数字签名过程及实现

网上通信双方互相**认证身份**后,即可发送签名的数据电文。**数字签名全过程**分两部分:签名与验证.数字签名与验证过程和技术**实现的原理**。

发方将原文用**哈希算法**求得数字摘要,用**签名私钥**对数字摘要加密求得数字签名,然后将原文与数字签名一起发送给收方;收方验证签名,即用发方的公钥解密数字签名,得出数字摘要;收方将原文采用同样哈希算法又得一新的数字摘要,将两个数字摘要进行比较,如果两者匹配,说明经数字签名的电子文件传输成功。



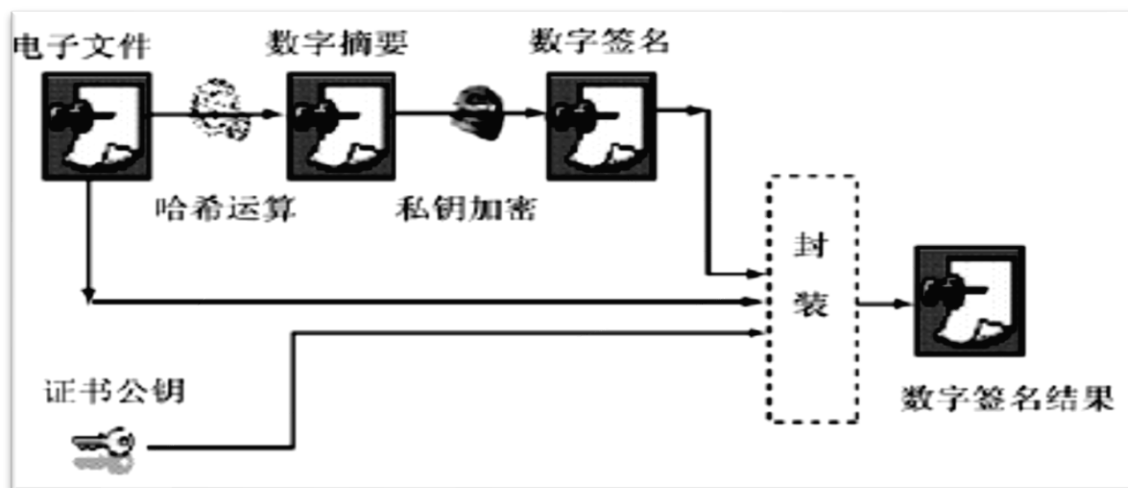
6.2 身份认证技术与数字签名

3. 数字签名过程及实现

(1) 数字签名的操作过程

需要有发送签名证书的私钥及其验证公钥。具体操作过程：

- ①生成被签名的电子文件（《电子签名法》中称为数据电文），
- ②对电子文件用哈希算法做数字摘要，
- ③对数字摘要用签名私钥做非对称加密，即做数字签名；
- ④将以上的签名和电子文件原文以及签名证书的公钥加在一起进行封装，形成签名结果发送给收方，待收方验证。



数字签名操作过程

6.2 身份认证技术与数字签名

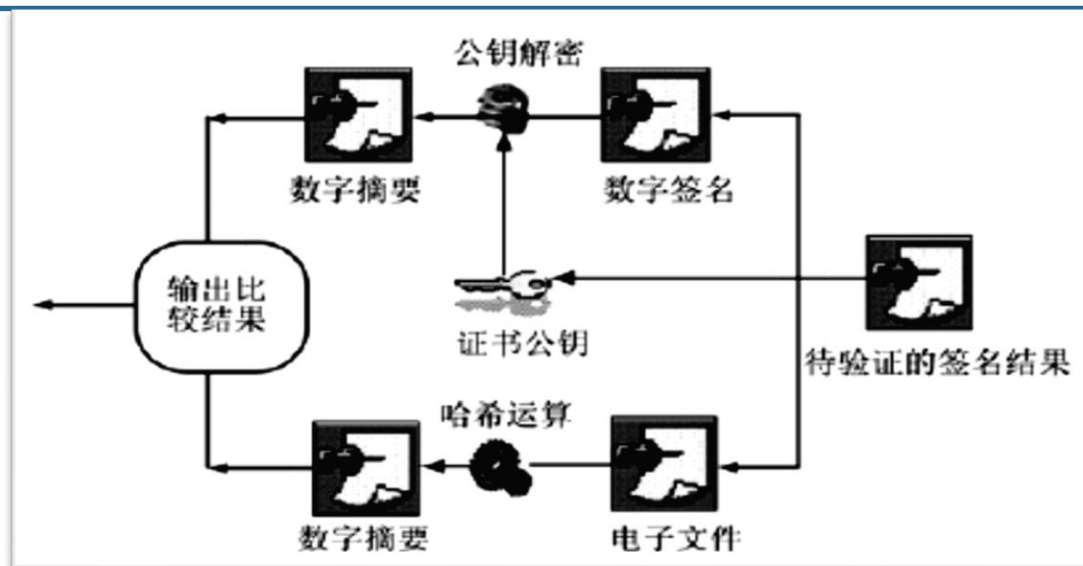
3. 数字签名过程及实现

(2) 数字签名的验证过程

收方收到发方的签名后进行签名验证的具体操作过程如图所示。

收到数字签名包括数字签名、电子原文和发方公钥，即待验证的数据。

收方进行签名验证过程：收方先用发方公钥解密数字签名，导出数字摘要，并对电子文件原文做同样哈希算法得一新数字摘要，将两个摘要哈希值比较，结果相同签名得到验证，否则签名无效。《电子签名法》中要求对签名不可改动，对签署的内容和形式也不可改动。



数字签名验证过程

6.2 身份认证技术与数字签名

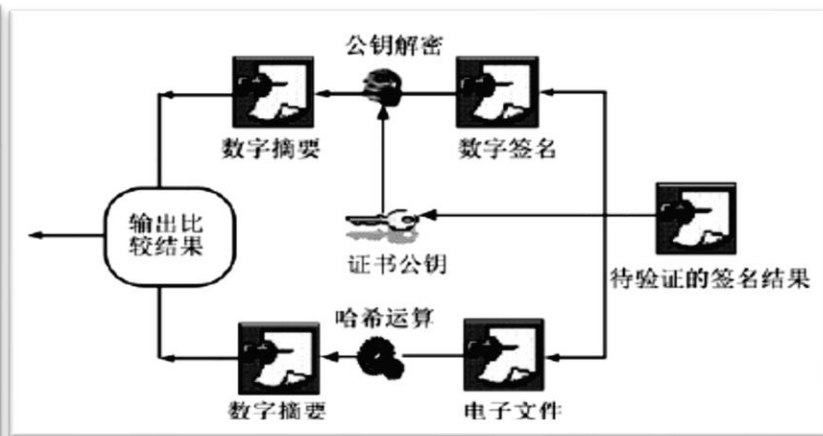
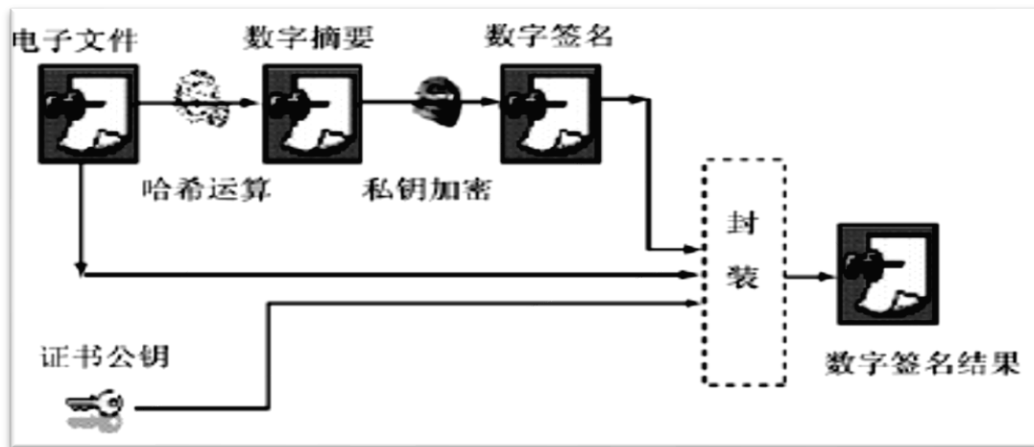
3. 数字签名过程及实现

如果收方对发方数字签名验证成功，就可以说明3个实质性的问题：

1) **该电子文件确实是由签名者的发方所发出的**，电子文件来源于该发送者。因为签署时电子签名数据由电子签名人所控制。

2) **被签名的电子文件确实是经发方签名后发送的**，说明发方使用自己的私钥做的签名，并得到验证，达到不可否认的目的。

3) **收方收到的电子文件在传输中没有被篡改**，保持了数据的完整性，因为签署后对电子签名的任何改动都能够被发现。《电子签名法》中规定：“安全的电子签名具有与手写签名或者盖章同等的效力”。

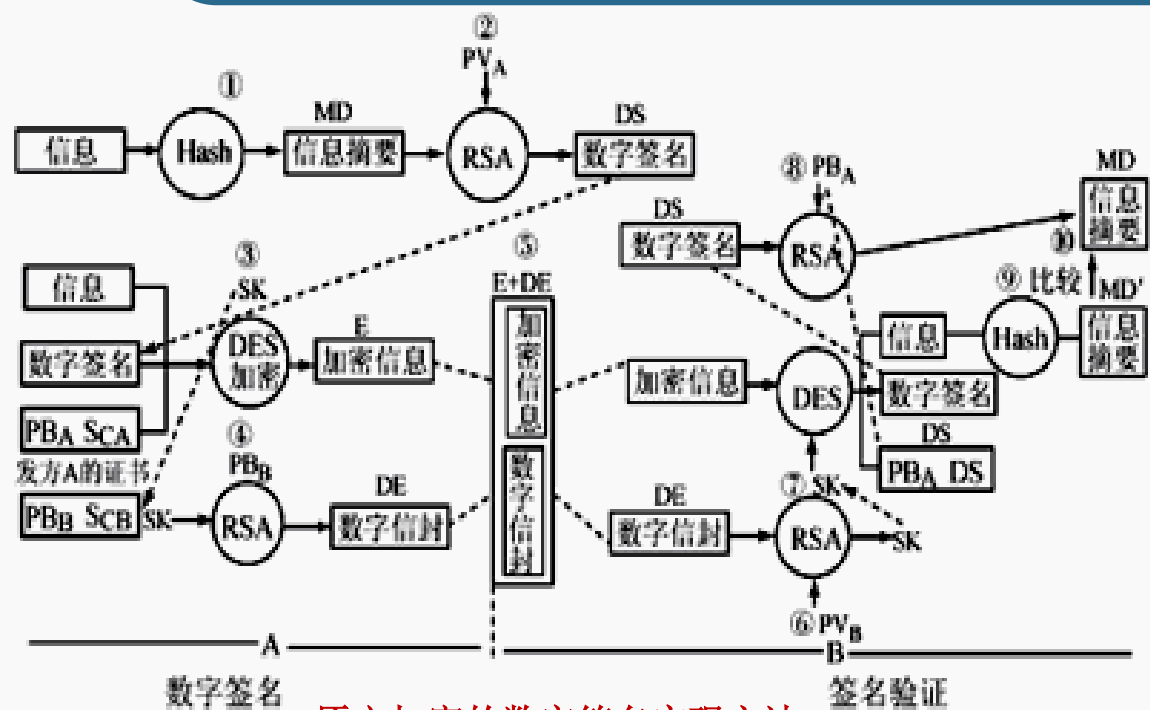


6.2 身份认证技术与数字签名

3. 数字签名过程及实现

(3) 原文保密的数据签名的实现方法

上述数字签名原理中定义的对原文做数字摘要及签名并传输原文，实际上在很多场合传输的原文要求保密，不许别人接触。要求对原文加密的数字签名方法的实现涉及到“数字信封”问题，此处理过程稍复杂一些，但数字签名的基本原理仍相同，签名过程如图所示。



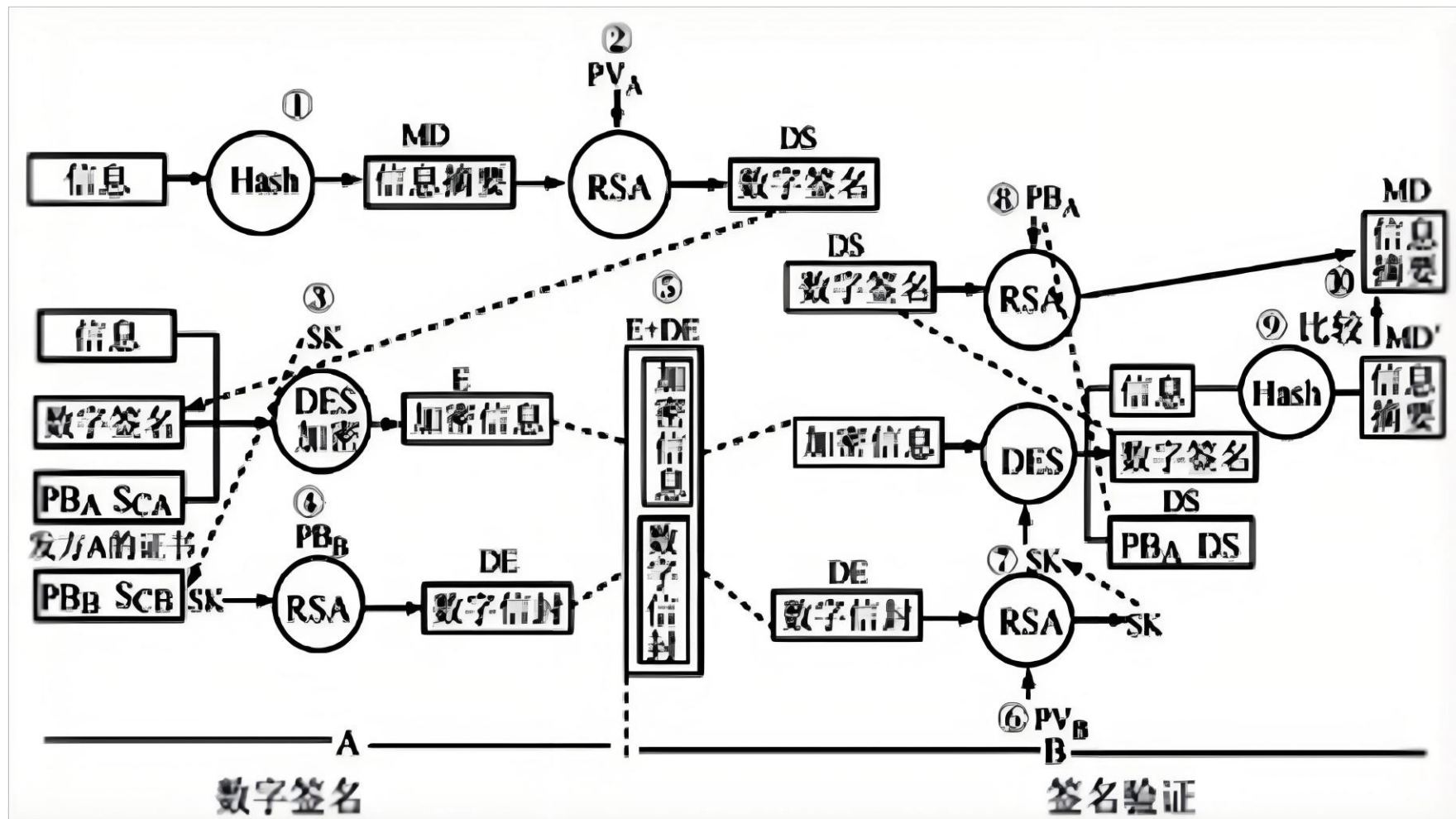
原文加密的数字签名实现方法

讨论思考:

- 1) 常用的身份认证技术有哪些?
- 2) Kerberos认证的过程是怎样的?
- 3) 什么是数字证书? CA的主要职能和功能是什么?
- 4) 什么是一次性口令认证? 为什么要采用一次性口令认证技术?
- 5) 数字签名的概念及方法是什么?
- 6) 数字签名的功能和种类有哪些?

6.2 身份认证技术与数字签名

3. 数字签名过程及实现





6.3 访问控制技术

6.3.1 访问控制概述

【案例 6-4】 在 Gartner 发布的《身份和访问管理 2020》中提出：所有 500 强企业的 IT 部门都必须推进身份认证和访问管理（Identity and Access Management, IAM）建设，IAM 应重点关注无密码认证、增强的消费者隐私要求及混合/多云环境。

6.3 访问控制技术

6.3.1 访问控制概述

1. 访问控制的概念

访问控制（Access Control）是对资源对象的访问者授权、控制的方法及运行机制，即通过对访问的申请、批准和撤销的全过程进行有效的控制，从而确保只有合法用户的合法访问才能给予批准，而且相应的访问只能执行授权的操作。

访问控制包含三方面含义：

- 一是机密性控制，保证数据资源不被非法**读出**；
- 二是完整性控制，保证数据资源不被非法**增加、改写、删除和生成**；
- 三是有效性控制，保证资源不被非法访问主体**使用和破坏**。

访问控制是系统保密性、完整性、可用性和合法使用性的基础，是网络安全防范和保护的主要策略。



6.3 访问控制技术

6.3.1 访问控制概述

访问控制三个要素：

(1) 主体**S (Subject)**是指一个**提出请求或要求的实体**，是动作的发起者，但不一定是动作的执行者。可以是某个用户或是用户启动的进程、程序、服务和设备。

(2) 客体**O (Object)**是**接受其他实体访问的被动实体**。客体的概念也很广泛，凡是可以被操作的信息、资源、对象都可以认为是客体，如文件、设备、信号量等。在信息社会中，客体可以是信息、文件、记录等的集合体，也可以是网络上的硬件设施、无线通信中的终端，甚至一个客体可以包含另外一个客体。

(3) 控制策略**A (Attribution)**是主体对客体的**访问规则集**。这个规则集直接定义了主体对客体的动作行为和客体对主体的条件约束，如拒绝访问、授权许可、禁止操作等。访问策略实际上体现了一种授权行为，也就是客体对主体的权限允许。



6.3 访问控制技术

6.3.1 访问控制概述

访问控制的目的是为了限制访问主体对访问客体的访问权限，从而使计算机网络系统在合法范围内使用；它决定用户能做什么，也决定代表一定用户身份的进程能做什么。

访问控制需要完成两个主要任务：

识别和确认访问系统的用户；

决定该用户可以对某一系统资源进行何种类型的访问。

6.3 访问控制技术

2. 访问控制的功能和内容

访问控制的主要功能包括：保证合法用户**访问**受权保护的网络安全资源，防止非法的主体**进入**受保护的网络安全资源，或防止合法用户对受保护的网络安全资源进行非授权的**访问**。

访问控制首先需要对用户身份合法性进行验证，同时利用控制策略进行管理。当用户身份和访问权限被验证之后，还需要对越权操作进行监控。

6.3 访问控制技术

2. 访问控制的功能和内容

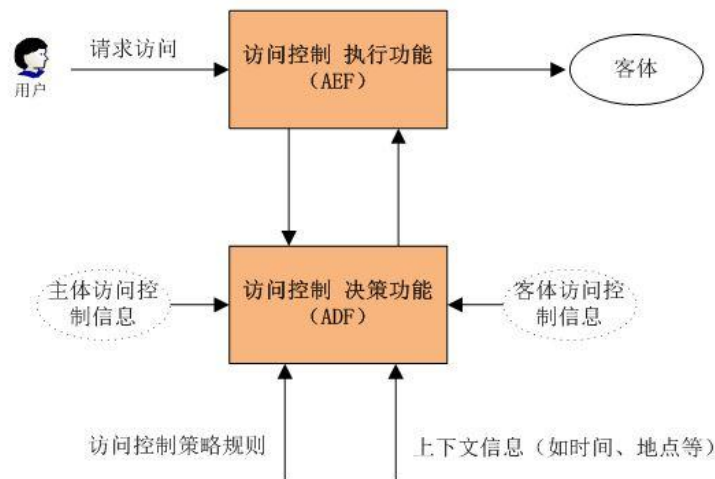
访问控制的内容包括三个方面:

(1) **认证**：包括主体对客体的识别认证和客体对主体检验认证。

(2) **控制策略具体实现**: 访问控制策略的实现依赖于**访问控制策略的设计**, 需要**规定**用户访问资源的权限, **防止**资源丢失、泄密或非法使用。例如是内部用户还是外部用户访问、通信采用端口号还是 IP 地址、信息的安全级别和分类、访问权限的更新和维护等。

(3) **安全审计**:使系统自动记录网络中的“正常”操作、“非正常”操作以及使用时间、敏感信息等。

审计类似于飞机上的“黑匣子”，它为系统进行事故原因查询、定位、事故发生前的预测、报警以及为事故发生后的实时处理提供详细可靠的依据或支持。



访问控制功能及原理

6.3 访问控制技术

6.3.2 访问控制的模型和分类

1. 访问控制的实现方法

(1) 访问控制矩阵 (Access Control Matrix, ACM)

访问控制矩阵模型的基本思想是将所有的访问控制信息存储在一个矩阵中进行集中管理。当前的访问控制模型都是在此基础上建立起来的。

如图所示，访问矩阵的每行对应一个主体，是访问操作中的**主动实体**；每列对应一个客体，是访问操作中的**被动实体**；每个单元格描述主体可以对客体执行的访问操作。

Subjects \ Objects	O ₁	O ₂	O ₃
S ₁	Read/Writes		
S ₂	Execute	Write	
S ₃			Read

6.3 访问控制技术

6.3.2 访问控制的模型和分类

1. 访问控制的实现方法

(1) 访问控制矩阵 (Access Control Matrix, ACM)

系统的访问控制矩阵表示了系统的一种**保护状态**，如果系统中用户发生了变化、访问对象发生了变化或者某一用户对某个对象的访问权限发生了变化，都可以看作是系统的保护状态发生了变化。由于访问控制矩阵只规定了系统状态的迁移必须有规则，而没有规定是什么规则，因此该模型的**灵活性很强**，但却给系统埋下了潜在的**安全隐患**。另外，当系统拥有大量用户和客体时，访问控制矩阵将变得十分**臃肿且稀疏**，**效率也会很低**。因此，实际的访问控制系统很少采用矩阵形式，更多的是其替代形式：**访问控制列表和能力表**。

Subjects \ Objects	O ₁	O ₂	O ₃
S ₁	Read/Writes		
S ₂	Execute	Write	
S ₃			Read

6.3 访问控制技术

6.3.2 访问控制的模型和分类

1. 访问控制的实现方法

(2) 访问控制列表 (ACL)

是按访问控制矩阵的列实施对系统中客体的访问控制。

每个客体都有一张ACL, 用于说明可以访问该客体的主体及其访问资源。对于共享客体, 系统只要维护一张ACL即可。访问控制列表通常设置在路由器中, 用来告诉路由器哪些数据包可以接收、哪些数据包需要拒绝。至于数据包是被接收还是拒绝, 可以由类似于源地址、目的地址、端口号等的特定指示条件来决定。

访问控制列表具有许多**作用**, 如限制网络流量、提高网络性能; 通信流量的控制, 例如ACL可以限定或简化路由更新信息的长度, 从而限制通过路由器某一网段的通信流量; 提供网络安全访问的基本手段; 在路由器端口处决定哪种类型的通信流量被转发或被阻塞, 例如, 用户可以允许E-mail通信流量被路由, 拒绝所有的 Telnet通信流量等。

6.3 访问控制技术

6.3.2 访问控制的模型和分类

1. 访问控制的实现方法

(2) 访问控制列表 (ACL)

由于 ACL 是随着客体在系统中分布存储的，如果要**从主体的角度实施权限管理**，确定一个主体的所有访问权限就需要遍历分布式系统中所有的 ACL，而这通常是十分**困难**的。因此，在分布式系统中实施访问控制通常需要采用能力表的方法。

【案例 6-5】 采用 DAC 集中式操作系统，如 Linux、Windows 等，全部采用 ACL 的方式实现。例如在 Linux 系统中，客体都通过指针指向一个 ACL 列表的数据结构，在该数据结构中以链表的形式依次存储了客体拥有者、拥有者所属用户组及其他用户所具有的读、写、执行权限。

6.3 访问控制技术

6.3.2 访问控制的模型和分类

【案例 6-5】 采用 DAC 集中式操作系统，如 Linux、Windows 等，全部采用 ACL 的方式实现。例如在 Linux 系统中，客体都通过指针指向一个 ACL 列表的数据结构，在该数据结构中以链表的形式依次存储了客体拥有者、拥有者所属用户组及其他用户所具有的读、写、执行权限。

```
jingkun — ssh jingkun@124.16.70.17 — 80x24
[jingkun@nvidia-DGX-Station:/home/liumiao$ ls -la
总用量 6018032
drwxr-xr-x 47 liumiao liumiao      4096 2月 16 16:24 .
drwxr-xr-x  8 root    root        4096 12月 12 10:03 ..
drwxrwxr-x 13 liumiao liumiao      4096 9月  1 2023 12
drwxrwxr-x  4 liumiao liumiao      4096 4月 19 2022 13
drwxrwxr-x  7 liumiao liumiao      4096 6月 14 2022 14
drwxrwxr-x  4 liumiao liumiao      4096 10月 18 2023 15
drwxrwxr-x 39 liumiao liumiao      4096 11月 25 17:37 16
-rw-r--r--  1 liumiao liumiao     28336 1月 19 2022 1.sh
drwxrwxr-x 13 liumiao liumiao      4096 3月 19 2024 ADPRPlacer
drwxr-xr-x 26 liumiao liumiao      4096 11月 25 17:42 anaconda3
-rw-r----- 1 liumiao liumiao    110155 4月  9 2024 auth.log
-rw-r----- 1 liumiao liumiao  13105989 4月  9 2024 auth.log.1
-rw-r----- 1 liumiao liumiao   6994999 4月  9 2024 auth.log.2.gz
-rw-r----- 1 liumiao liumiao   2053793 4月  9 2024 auth.log.3.gz
-rw-r----- 1 liumiao liumiao   4705920 4月  9 2024 auth.log.4.gz
-rw-----  1 liumiao liumiao     77614 2月 16 16:24 .bash_history
-rw-r--r--  1 liumiao liumiao      220 1月 19 2022 .bash_logout
-rw-r--r--  1 liumiao liumiao      220 1月 18 2022 .bash_logout1
-rw-r--r--  1 liumiao liumiao     5042 3月  6 2024 .bashrc
-rw-r--r--  1 liumiao liumiao     3771 1月 18 2022 .bashrc1
-rw-rw-r--  1 liumiao liumiao    98028 4月 23 2024 batch_process_ac97_ctrl_
syn_000_balance.ps
```

6.3 访问控制技术

6.3.2 访问控制的模型和分类

1. 访问控制的实现方法

(3) 能力表 (Capability List, CL)

能力表访问控制方法借用了系统对文件的目录管理机制，为每一个欲实施访问操作的主体，建立一个能被其访问的“客体目录表”，如某个主体的客体目录表可能如表所示。

客体目录表

客体1: 权限	客体2: 权限	客体i: 权限	客体j: 权限	客体n: 权限
---------	---------	---------	---------	---------

目录中的每一项称为**能力**，它由特定客体和相应访问权限组成，表示主体对该客体所拥有的访问能力。把主体所拥有的所有能力组合起来就得到了该主体的能力表，这种方法相当于把访问控制矩阵按行进行存储。

6.3 访问控制技术

6.3.2 访问控制的模型和分类

1. 访问控制的实现方法

访问控制列表 (ACL) VS 能力表 (CL)

Objects		O ₁	O ₂	O ₃
Subjects				
CL	S ₁	Read/Writes		
	S ₂	Execute	Write	
	S ₃			Read

ACL

6.3 访问控制技术

2. 访问控制的模型

主要的访问控制模式主要有5种：

- (1) 自主访问控制 (DAC)
- (2) 强制访问控制 (MAC)
- (3) 基于角色的访问控制 (RBAC)
- (4) 基于任务的访问控制 (TBAC)
- (5) 基于属性的访问控制 (ABAC)



6.3 访问控制技术

2. 访问控制的模型

(1) 自主访问控制 (DAC)

自主访问控制 (Discretionary Access Control, DAC) 又称为**随意/任选访问控制**, 是在确认主体身份及所属组的基础上, 根据访问者的身份和授权决定访问模式、对访问进行限定的一种控制策略, 具有很大的**灵活性**, 并**易于理解、使用**。

存在2个主要缺陷。

1) 权限传播可控性差。因为这种机制允许用户自主地将自己客体的访问操作权转授给别的主体, 一旦转授给不可信主体, 那么该客体的信息就会被泄露。

2) 不能抵抗木马攻击。在该机制下, 某一合法用户可以任意运行一段程序来修改自己文件的访问控制信息, 系统无法区分这是用户的合法修改还是木马程序的非法修改。

6.3 访问控制技术

2. 访问控制的模型

(1) 自主访问控制 (DAC)

此外，因用户无意（如程序错误、误操作等）或不负责的操作而造成敏感信息的泄露问题，在DAC机制下也无法解决。

这些缺陷都使得自主访问控制的安全程度较低，难以独自支撑高安全等级要求的计算环境。

【案例 6-6】 Linux、UNIX、Windows Server 的操作系统都提供自主访问控制功能。在实现上，首先要对用户的身份进行鉴别，然后按照访问控制列表所赋予用户的权限允许和限制用户使用客体资源。主体控制权限的修改通常由特权用户或特权用户组（管理员）实现。



6.3 访问控制技术

2. 访问控制的模型

(2) 强制访问控制 (MAC)

最早出现在 20 世纪 70 年代，是源于美国政府和军方对信息保密性的要求以及防止特洛伊木马之类的攻击而研发的。

强制访问控制是根据客体中信息的敏感标签和访问敏感信息的主体访问等级，对客体访问实行限制的一种方法。

在强制访问控制中，用户的权限和客体的安全属性都是固定的，由系统决定一个用户对某个客体能否进行访问。它主要用于保护那些处理特别敏感数据（如政府保密信息或企业敏感数据）的系统。

所谓“强制”就是安全属性由系统管理员人为设置，或由操作系统自动按照严格的安全策略与规则进行设置，**用户和他们的进程不能修改这些属性。**

6.3 访问控制技术

(2) 强制访问控制 (MAC)

实质是对系统中所有客体和主体分配**敏感标签**。用户的敏感标签指定该用户的敏感等级或信任等级，也被称为**安全许可**。

文件的敏感标签说明要访问该文件的用户所必须具备的信任等级。**由两个部分组成**：类别和类集合。

类别也称安全级，是单一的、层次结构的，从高到低分为绝密级、机密级、秘密级和公开级**4级**。**类集合也称范畴级**，是非层次的，代表系统中信息的不同区域，类集合之间是包含、被包含或无关的关系。安全级中包括一个保密级别，范畴集中包含任意多个范畴，如：{机密：人事处，财务处，科技处}。

现实中安全管理员，很难在安全目标的保密性、可用性和完整性之间做出精准平衡。因此，**MAC模型分为加强数据保密性和以加强数据完整性为目的的两种类型**，如BLP模型、Biba模型、Clark-Wilson模型、Bion模型和China Wall模型等，其中最经典的模型是BLP模型和Biba模型。

6.3 访问控制技术

(2) 强制访问控制 (MAC)

BLP模型

全称 (Bell-LaPadula) 模型, 是符合军事安全策略的计算机安全模型。

BLP模型的安全规则:

简单安全规则: 安全级别低的主体不能读安全级别高的客体。

星属性安全规则: 安全级别高的主体不能往安全低级别的客体写。

强星属性安全规则: 不允许对另一级别进行读写。

自主安全规则: 使用访问控制矩阵来定义说明自由存取控制。

6.3 访问控制技术

(2) 强制访问控制 (MAC)

Biba模型

主要用于防止非授权修改系统信息，以保证系统的信息完整性。该模型能够防止数据从低完整性级别流向高完整性级别。

Biba模型的安全规则：

星完整性规则：完整性级别低的主体不能对完整性级别高的客体写数据。

简单完整性规则：完整性级别高的主体不能从完整性级别低的客体读取数据。

调用属性规则：完整性级别低的主体不能从完整性级别高的客体调用程序或服务。

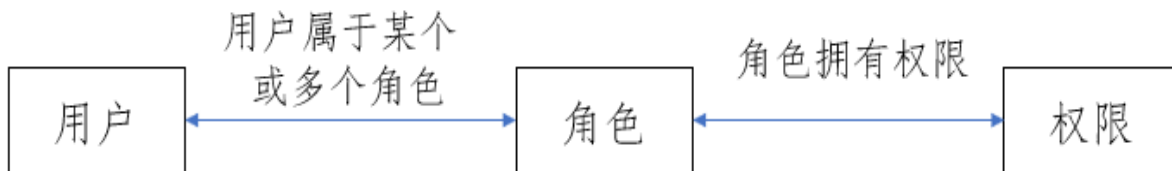
6.3 访问控制技术

2. 访问控制的模型

(3) 基于角色的访问控制 (RBAC)

20世纪90年代以来, 随着对在线的多用户、多系统研究的不断深入, 角色的概念逐渐形成, 并逐步产生了**基于角色的访问控制** (Role-Based Access Control, RBAC) 模型。

其**核心思想**是将访问许可权分配给一定的角色, 用户通过饰演不同的角色获得角色所拥有的访问许可权, 如图所示。





6.3 访问控制技术

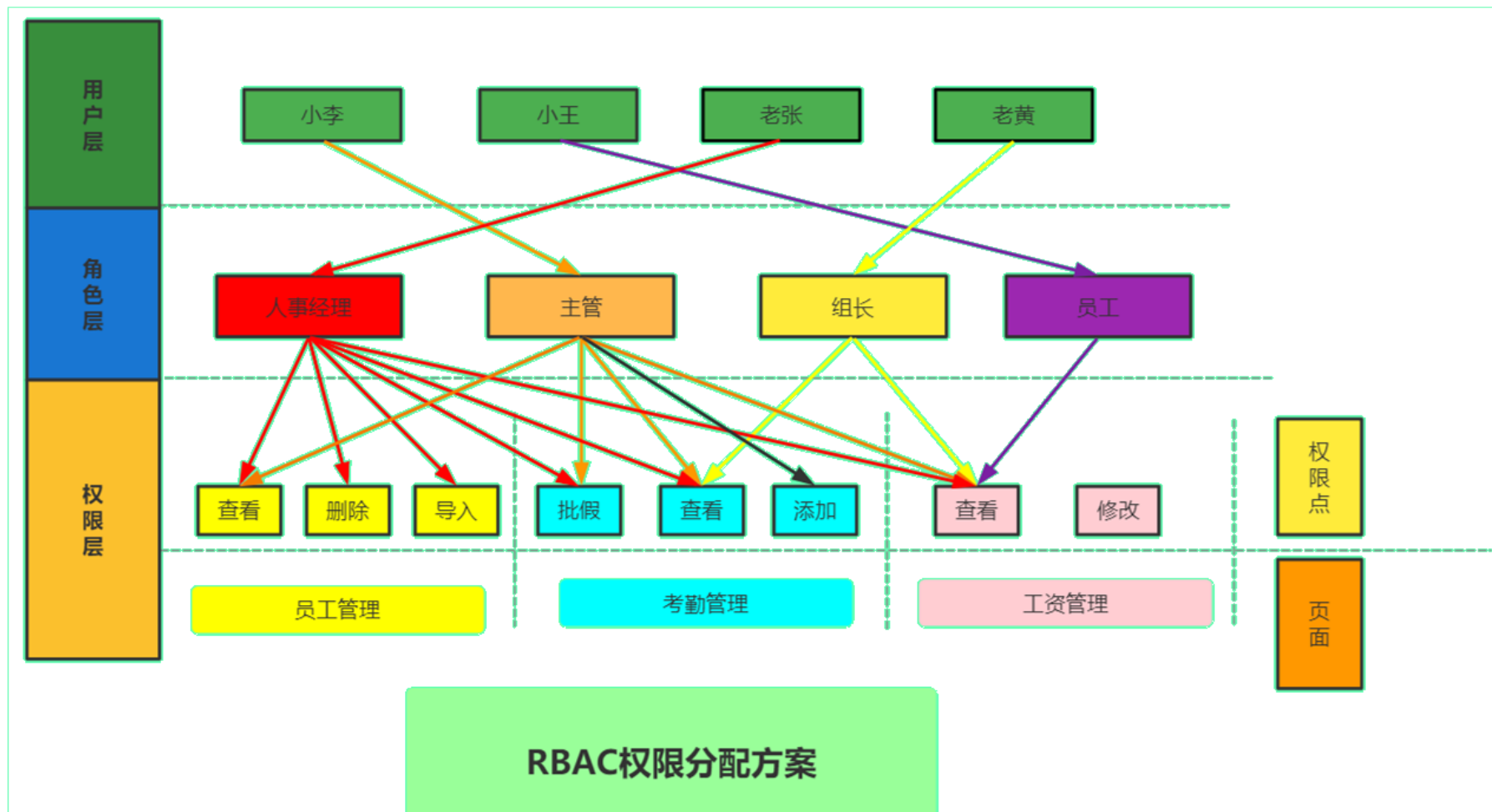
(3) 基于角色的访问控制 (RBAC)

角色充当着主体（用户）和客体之间关系的桥梁，角色不仅是用户的集合，也是一**系列权限的集合**。当用户或权限发生变动时，系统可以很灵活地将该用户从一个角色移到另一个角色来实现权限的转换，降低了管理的复杂度。

另外在组织机构发生职能改变时，应用系统只需要对角色进行重新授权或取消某些权限，就可以使系统重新适应需要。与用户相比，角色是相对稳定的。

角色由系统管理员定义，角色成员的增减也只能由系统管理员来执行，即只有系统管理员有权定义和分配角色。用户与客体无直接联系，只有通过角色才享有该角色所对应的权限，从而访问相应的客体。

6.3 访问控制技术



6.3 访问控制技术

6.3.2 访问控制的模型和分类

(4) 基于任务的访问控制 (TBAC)

传统的访问控制模型都是**基于主体-客体观点的被动安全模型**，在被动安全模型中**授权是静态**的，没有考虑到操作的上下文。

因此存在一些**缺陷**：在执行任务之前，主体就已权限，或者在执行完任务后继续拥有权限，这样就导致主体拥有额外的权限，系统安全面临与大的危险。

针对上述问题，人们提出了**基于任务的动向控制 (TBAC) 模型**。



6.3 访问控制技术

6.3.2 访问控制的模型和分类

(4) 基于任务的访问控制 (TBAC)

基于任务的访问控制 (TBAC) 模型是一种**以任务为中心**的，并**采用动态授权**的主动安全模型，**该模型的基本思想是**：授予给用户的访问权限，不仅仅依赖主体、客体，还依赖于主体当前执行的任务、任务的状态。当任务处于活动状态时，主体拥有访问权限。一旦任务被挂起，主体拥有的访问权限就被冻结。如果任务恢复执行，主体将重新拥有访问权限。任务处于终止状态时，主体拥有的权限马上被撤销。TBAC适用于 workflow、分布式处理、多点访问控制的信息处理以及事务管理系统中的决策制定，但最显著的应用还是在安全 workflow 管理中。



6.3 访问控制技术

6.3.2 访问控制的模型和分类

(5) 基于属性的访问控制 (ABAC)

基于用户、资源、操作和运行上下文属性所提出的**基于属性的访问控制** (ABAC) 将主体和客体的属性作为基本的决策要素, 灵活利用请求者所具有的属性集合决定是否赋予其访问权限, 能够很好地将策略管理和权限判定相分离。由于属性是主体和客体内在固有的, 不需要手工分配, 同时访问控制是多对多方式, 使得ABAC管理上相对简单。并且属性可以多个角度对实体进行描述, 因此可根据实际情况改变策略。例如, 基于使用的访问控制模型 (Usage Control, UCON) 引入了执行访问控制所必须满足的约束条件 (如系统负载、访问时间限制等)。

6.3 访问控制技术

6.3.2 访问控制的模型和分类

(5) 基于属性的访问控制 (ABAC)

下一代访问控制模型

UCON (Usage control) 模型的访问流程包括以下步骤:

访问请求: 访问请求是主体 (用户、程序、设备等) 向系统请求对资源进行操作的行为。访问请求包含主体标识、资源标识、操作类型以及其他访问上下文信息 (如时间、位置、设备状态等)。

上下文获取: 系统获取访问请求所需的上下文信息, 包括当前的环境条件、主体的属性和行为历史等。

访问控制决策、决策结果、访问控制调整、记录与审计、执行访问操作。

整个UCON模型的访问流程是一个动态的过程, 在访问过程中可以根据实时的访问上下文和决策结果进行调整和控制。这种实时的、动态的访问控制机制能够更好地适应复杂的访问需求和变化的环境条件。



6.3 访问控制技术

6.3.2 访问控制的模型和分类

(5) 基于属性的访问控制 (ABAC)

此外，ABAC 的强扩展性使其可以同加密机制等数据隐私保护机制相结合，在实现细粒度访问控制的基础上，保证用户数据不会被分析及泄漏。例如，基于属性的加密 (Attribute-based Encryption, ABE) 方法。上述优点使 ABAC 模型能够有效解决动态大规模环境下的细粒度访问控制问题，是新型计算环境中理想的访问控制模型。

6.3 访问控制技术

6.3.3 访问控制的安全策略

1. 访问控制安全策略

访问控制技术的实现以访问控制策略的表达、分析和实施为主。其中，访问控制策略定义了系统安全保护的目标，访问控制模型对访问控制策略的应用和实施进行了抽象和描述，访问控制框架描述了访问控制系统的具体实现、组成架构和部件之间交互流程。

访问控制安全策略主要有如下7种：

(1) 入网访问控制策略。

为网络访问提供第一层访问控制。控制哪些用户能够登录到服务器并获取网络资源，控制准许用户入网的时间和登录入网的工作站。用户的入网访问控制分为：用户名和口令的识别与验证、用户账号的默认限制检查。只要其中的任何一个步骤未通过，该用户便不能进入该网络。

6.3 访问控制技术

6.3.3 访问控制的安全策略

1. 访问控制安全策略

(2) 网络权限控制策略。

是针对网络非法操作所提出的一种安全保护措施。可对下列用户和用户组赋予:①**特殊用户**, 指具有系统管理权限的用户;②**一般用户**, 系统管理员根据用户的实际需要为他们分配操作权限;③**审计用户**, 负责网络的安全控制与资源使用情况的审计。用户对网络资源的访问权限可以用一个访问控制表来描述。

(3) 目录级安全控制策略。

网络应允许**控制用户对目录、文件、设备的访问**, 用户在目录一级指定的权限对所有文件目录有效, 用户还可进一步指定对目录下的子目录和文件的访问权限。

6.3 访问控制技术

6.3.3 访问控制的安全策略

1. 访问控制安全策略

(4) 属性安全控制策略。

网络系统管理员给文件、目录指定访问属性，并与网络服务器的文件、目录网络设备联系起来，在权限安全的基础上提供更进一步的安全性。网络上的资源都应预先标出一组安全属性，用户对网络资源的访问权限对应一张访问控制表，用以表明用户对网络资源的访问能力。

(5) 网络服务器安全控制策略。

网络服务器的安全控制包括：可以设置口令锁定服务器控制台，以防止非法用户修改、删除重要信息或破坏数据；可以设定服务器登录时间限制、非法访问者检测和关闭的时间间隔等。

6.3 访问控制技术

6.3.3 访问控制的安全策略

1. 访问控制安全策略

(6) 网络监控和锁定控制策略。

网络管理员应对网络实施**监控**，服务器要**记录**用户对网络资源的访问。如有非法的网络访问，服务器应以**图形、文字或声音等形式报警**，以引起网络管理员的注意。如果入侵者试图进入网络，网络服务器会自动记录尝试进入网络的次数，当非法访问的次数达到设定的数值时，该用户账户就会被**自动锁定**。

(7) 网络端口和结点的安全控制策略。

网络中服务器的端口往往使用自动回呼设备、静默调制解调器加以保护，并以加密的形式来识别节点的身份。自动回呼设备用于防止假冒合法用户，**静默调制解调器**用以防范黑客的自动拨号程序对计算机进行攻击。网络还常对服务器端和用户端采取控制，用户必须携带**证实身份的验证器**(如智能卡、磁卡、安全密码发生器等)，在对用户的身份进行验证之后，才允许用户进入。之后，用户端和服务器再进行相互验证。

6.3 访问控制技术

6.3.3 访问控制的安全策略

2. 安全策略实施原则

访问控制安全策略是指在某个**自治区域**内（属于某个组织/机构的一系列处理和通信资源范畴），**用于**所有与安全相关活动的一套**访问控制规则**。其**安全策略**有**三种类型**：基于身份的安全策略、基于规则的安全策略和综合访问控制方式。

访问控制安全策略原则**集中在**主体、客体和**安全控制规则集三者之间的关系**。

- （1）最小特权原则。
- （2）最小泄露原则。
- （3）多级安全策略。



6.3 访问控制技术

6.3.3 访问控制的安全策略

2. 安全策略实施原则

(1) 最小特权原则。是指主体执行操作时，按照主体所需权利的最小化原则分配给主体权利。其优点是最大限度地限制了主体实施授权行为，可以避免来自突发事件、错误和未授权主体的危险。

(2) 最小泄露原则。是指主体执行任务时，按照主体所需要知道的信息最小化的原则分配给主体权利。

(3) 多级安全策略。是指主体和客体间的数据流向和权限控制按照安全级别的绝密(TS)、秘密(S)、机密(C)、限制(RS)和无级别(U) 5 级来划分。多级安全策略的优点是避免了敏感信息的扩散。对于具有安全级别的信息资源，只有安全级别比它高的主体才能够访问。

6.3 访问控制技术

6.3.3 访问控制的安全策略

3. 访问控制安全策略的实现

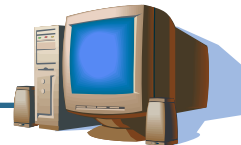
访问控制安全策略两种实现方式：

(1) 基于身份的安全策略

基于身份的安全策略是过滤对数据或资源的访问，只有通过认证的主体才能正常使用客体的资源。基于身份的安全策略包括基于个人的策略和基于组的策略，主要有两种基本的实现方法：能力表和访问控制表。

(2) 基于规则的安全策略

策略中的授权通常依赖于敏感性。在安全策略系统中，所有数据和资源都标注了安全标记，用户的活动进程与其原发者具有相同的安全标记。



6.3 访问控制技术

6.3.4 认证服务与访问控制系统

1. AAA技术概述

在新的网络应用环境中，虚拟专用网（VPN）、远程拨号、移动办公室等网络移动接入应用非常广泛，传统用户身份认证和访问控制机制已经无法满足广大用户的需求，由此产生了**AAA认证授权机制**，**主要包括**如下3个部分。

- 1) **认证（Authentication）**。对网络用户身份进行识别后，才允许远程登入访问网络资源。
- 2) **鉴权（Authorization）**。为远程访问控制提供方法，如一次性授权或给予特定命令或服务的授权。
- 3) **审计（Accounting）**。主要用于网络计费、审计和制作报表。

6.3 访问控制技术

6.3.4 认证服务与访问控制系统

2. 远程登入认证

远程登入认证也称**远程授权接入用户服务** (Remote Authentication Dial In User Service , **RADIUS**)，主要用于管理远程用户的网络登入，是目前应用最广泛的AAA协议。

主要基于C/S架构，其客户端最初是NAS (Net Access Server) 服务器，现在任何运行RADIUS客户端软件的计算机都可以成为其客户端。RADIUS协议认证机制灵活，可采用PAP、CHAP或UNIX登入认证等多种方式。

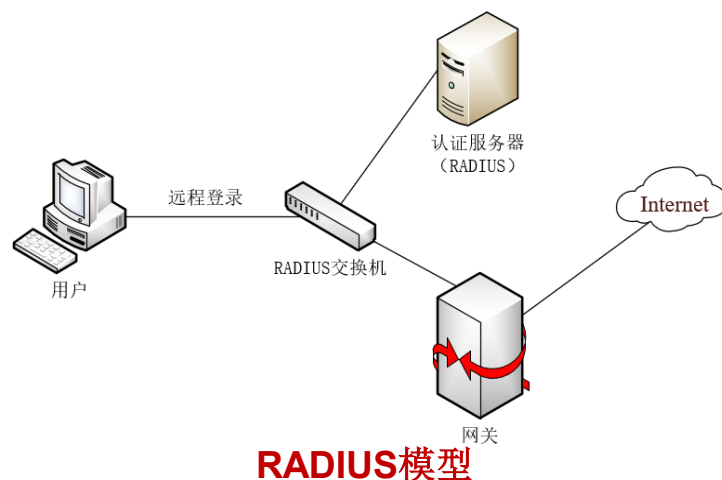


6.3 访问控制技术

6.3.4 认证服务与访问控制系统

2. 远程登入认证

RADIUS是一种完全开放的协议，分布源码格式，这样，任何安全系统和厂商都可以用，并且RADIUS可以和其它AAA安全协议共用。此协议规定了网络接入服务器与RADIUS服务器之间的消息格式。此服务器接受用户的连接请求，根据其账户和密码完成验证后，将用户所需的配置信息返回给网络接入服务器。该服务器同时审计并记录有关信息其模型如图所示。



6.3 访问控制技术

6.3.4 认证服务与访问控制系统

2. 远程登入认证

(1) RADIUS协议的主要工作过程

- 远程用户通过网络连接到接入服务器，并将登入信息发送到其服务器。
- RADIUS服务器根据用户输入的账号和密码对用户进行身份认证，并判断是否允许用户接入。请求批准后，服务器还要对用户进行相应的鉴权。
- 鉴权完成后，服务器将响应信息传递给网络接入服务器和计费服务器，网络接入服务器根据当前配置来决定针对用户的响应策略。

6.3 访问控制技术

6.3.4 认证服务与访问控制系统

2. 远程登入认证

(2) RADIUS的加密方法

对于重要的数据包和用户口令，RADIUS协议可使用MD5算法对其进行加密，在其客户端（NAS）和服务端（RADIUS服务器）分别存储一个密钥，利用此密钥对数据进行算法加密处理，密钥不宜在网络上传送。

(3) RADIUS的重传机制

RADIUS协议规定了重传机制。如果NAS向某个RADIUS服务器提交请求没有收到返回信息，则可要求备份服务器重传。由于有多个备份服务器，因此NAS要求重传时可采用轮询方法。如果备份服务器的密钥与以前的密钥不同，则需要重新进行认证。

6.3 访问控制技术

6.3.4 认证服务与访问控制系统

3. 终端访问控制器访问控制系统

终端访问控制器访问控制系统（TACACS）由RFC1492定义，其功能是通过一个或几个中心服务器为网络设备提供访问控制服务，也是AAA协议。标准的TACACS协议只认证用户是否可以登录系统，目前应用很少。取而代之的是TACACS+，也是一种为路由器、网络访问服务器和其他互联计算设备通过一个或多个集中的服务器提供访问控制的协议。

TACACS+提供了独立的认证、授权和记账服务，由思科（Cisco）公司提出，主要应用于Cisco公司的产品中，运行于TCP协议之上。



6.3 访问控制技术

6.3.5 准入控制技术

1. 准入控制技术概述

网络准入控制是一种网络安全管理技术，是主动式的对入网用户进行身份识别和安全评估，只有符合安全标准的终端才能够准许访问企事业单位网络，仅允许审批后的终端用户使用网络资源，从而达到保障整个网络安全的目的。当前，**网络准入控制技术架构**主要有以下3种。

- 1) 基于端点系统的架构 Software-base NAC
- 2) 基于基础网络设备联动的架构 Infrastructure-base NAC
- 3) 基于应用设备的架构 Appliance-base NAC

6.3 访问控制技术

6.3.5 准入控制技术

2. 准入控制技术方案介绍

在网络准入控制技术中，目前有几个主要的技术，思科的网络准入控制(NAC)，微软的网络接入保护(NAP)，Juniper的统一接入控制(UAC)，可信计算组织TCG的可信网络连接(TNC)，H3C的端点准入防御(EAD)等。

其它如赛门铁克、北信源、锐捷、启明星辰等国内外厂商也不约而同地基于自身特色提出了准入控制的解决方案。在原理上这些方案基本类似，但是，具体实现方式各不相同，**常用的几种网络准入控制技术有**：802.1x准入控制、DHCP准入控制、网关型准入控制、portal型准入控制、ARP型准入控制等。

6.3 访问控制技术

讨论思考：

- 1) 访问控制的概念和三要素是什么？
- 2) 访问控制模型主要有哪几种？
- 3) 访问控制安全策略的实施原则和实现方式是什么？
- 4) 什么是网络准入控制技术？其基本架构有哪几种？



6.4 安全审计与电子证据

【案例6-9】 2020 年，微软曝出前员工利用职务之便窃取并非法出售数字礼品卡获利超过 1000 万美元，同年 8 月，思科曝出离职员工删除 456 个虚拟机导致 1.6 万个 WebEx Teams 账户被关闭长达两周，使得思科因紧急修复并赔付客户而损失了 240 万美元。除类似的造成重大损失的内部威胁案例外，勒索软件等外部威胁往往也会利用企业内部人员安全意识薄弱、网络安全实践不规范以及业务流程和管理系统的缺陷等实施攻击。这些都凸显了安全审计的重要性。

系统安全审计是计算机网络安全的重要组成部分，是对防火墙技术和入侵检测技术等网络安全技术的重要补充和完善。在我国计算机系统安全保护等级划分中，系统审计保护属于第二级，是在用户自主保护级的基础上，要求创建和维护访问的审计跟踪记录，使所有用户对自身行为的合法性负责。

6.4 安全审计与电子证据

2006公安部
修订并实施

自主保护级

指导保护级

监督保护级

强制保护级

专控保护级

表3-3我国计算机信息系统安全保护等级划分

等级	名称	描述
第一级	用户自我保护级	安全保护机制可以使用户具备安全保护的能力,保护用户信息免受非法的读写破坏。
第二级	系统审计保护级	除具备第一级所有的安全保护功能外,要求创建和维护访问的审计跟踪记录,使所有用户对自身行为的合法性负责
第三级	安全标记保护级	除具备前一级所有的安全保护功能外,还要求以访问对象标记的安全级别限制访问者的权限,实现对访问对象的强制访问
第四级	结构化保护级	除具备前一级所有的安全保护功能外,还将安全保护机制划分为关键部分和非关键部分,对关键部分可直接控制访问者对访问对象的存取,从而加强系统的抗渗透能力
第五级	访问验证保护级	除具备前一级所有的安全保护功能外,还特别增设了访问验证功能,负责仲裁访问者对访问对象的所有访问

6.4 安全审计与电子证据

6.4.1 安全审计概述

1. 安全审计基本概念

安全审计（Audit）是指通过特定的安全策略,利用记录及分析系统活动和用户活动的历史操作事件,按照顺序检查、审查和检验每个事件的环境及活动。

主要目的在于5个方面:

- (1) 对潜在攻击者起到威慑和警示作用。
- (2) 测试系统的控制情况, 及时调整。
- (3) 对已出现的破坏事件, 做出评估并提供依据。
- (4) 对系统控制、安全策略与规程中的变更进行评价和反馈, 以便修订决策和部署。
- (5) 协助发现入侵或潜在的系统漏洞及隐患。

6.4 安全审计与电子证据

2. 安全审计的类型

从审计级别上可分为3种类型：

(1) 系统级审计。主要针对系统的登入情况、用户识别号、登入尝试的日期和具体时间(次数)、退出的日期和时间、所使用的设备、登入后运行程序等事件信息进行审查。

(2) 应用级审计。主要针对的是应用程序的活动信息。

(3) 用户级审计。主要是审计用户的操作活动信息。

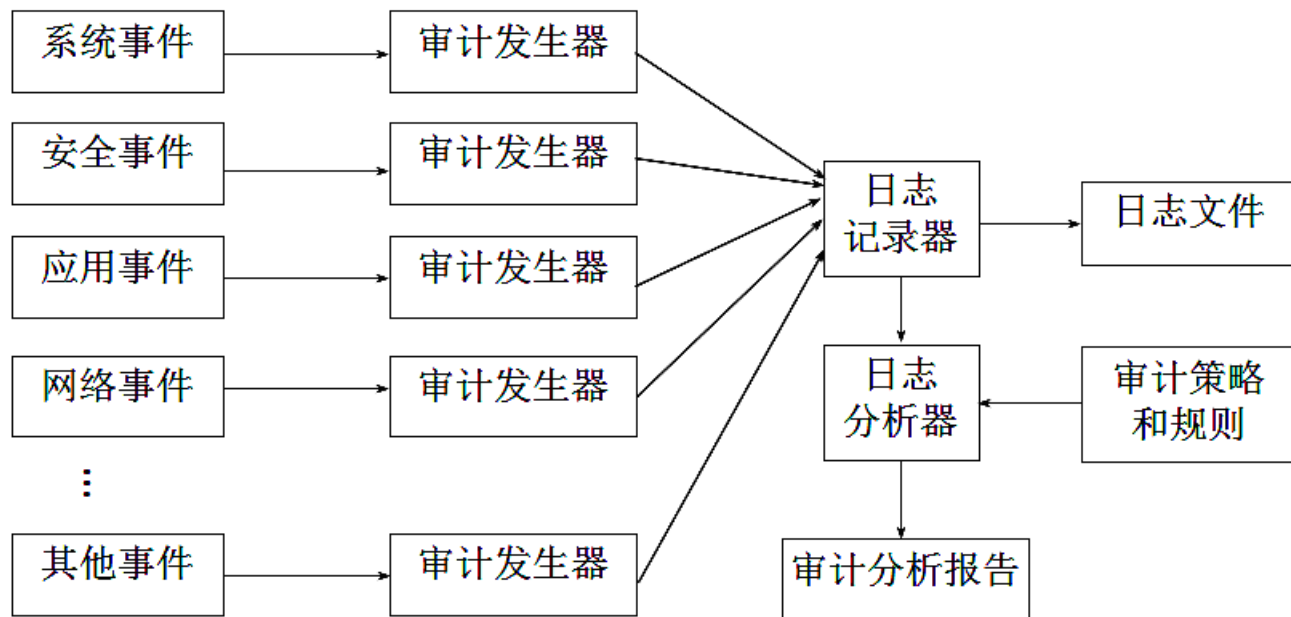
它们的区别主要体现在审计的对象、内容、深度和目的上。



6.4 安全审计与电子证据

3. 安全审计系统的基本结构

安全审计是通过对所关心的事件进行记录和分析来实现的，因此审计过程包括审计发生器、日志记录器、日志分析器和报告机制几部分，如图所示。



审计系统的基本结构

6.4 安全审计与电子证据

6.4.2 系统日志审计

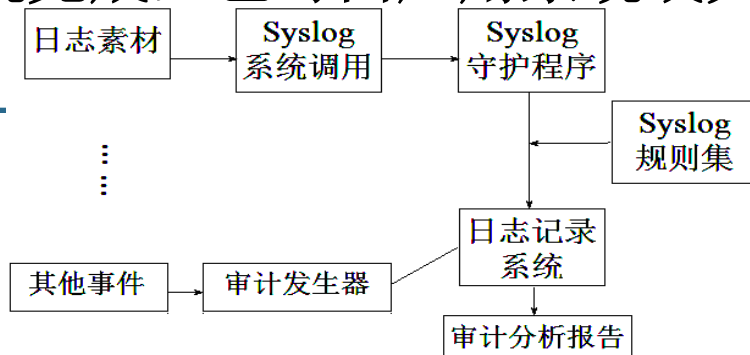
1. 系统日志的内容

系统日志主要根据网络安全级别及强度要求，选择记录部分或全部的系统操作。

对于单个事件行为，通常系统日志主要包括：事件发生的日期及时间、引发事件的用户IP地址、事件源及目的地位置、事件类型等。

2. 安全审计的记录机制

对各种网络系统应采用不同记录日志机制。记录方式有3种：由操作系统完成，也可由应用系统或其他专用记录系统完成。



Syslog是一种日志记录方法,程序中凡用其记录信息都发送到该服务器,根据配置决定此信息记录及位置,使系统内应用程序都能以统一方式记录日志,为系统日志的统一审计提供方便。

Syslog安全审计的记录机制



6.4 安全审计与电子证据

3. 日志分析

日志分析是通过**集中收集并监控**信息系统中的系统日志、设备日志、应用日志、用户访问行为、系统运行状态等各类信息，进行**过滤、归并和告警分析处理**，建立起一套面向整个系统日志的安全监控管理体系，将信息系统的安全状态以最直观的方式呈现给管理者，既能**提高安全审计的效率与准确性**，也有助于**及时发现安全隐患、快速定位故障、追查事故责任**，并能够**满足各项标准、法规的合规性管理要求**，其主要内容如下：

6.4 安全审计与电子证据

3. 日志分析

- 1)潜在侵害分析。日志分析可用一些规则监控审计事件，并根据规则发现潜在入侵。这种规则可以由已定义的可审计事件的子集所指示的潜在安全攻击的积累或组合，或其他规则。
- 2)异常检测。日志分析应确定用户正常行为的轮廓，当日志中的事件违反正常访问行为的轮廓，或超出正常轮廓一定的门限时，能指出将要发生的威胁。
- 3)简单攻击探测。日志分析可对重大威胁事件的特征进行明确的描述，当攻击出现时，及时指出。
- 4)复杂攻击探测。高级日志分析系统可检测多步入侵序列，当攻击出现时，可预测发生步骤。

6.4 安全审计与电子证据

3. 日志分析

经典日志分析工具:

<https://www.zhanid.com/webmaster/1712.html>

https://www.bilibili.com/read/cv39348445/?opus_fallback=1

6.4 安全审计与电子证据

4. 审计事件查阅

审计系统可成为追踪入侵、恢复系统的直接证据，甚至是司法依据，其自身的安全性更为重要。审计系统的安全主要包括审计事件查阅安全和存储安全。应严格限制审计事件的查阅，不能篡改日志。通常以不同的层次保证查阅安全（保护查阅安全措施）：

- 1) **审计查阅**。审计系统以可理解的方式为授权用户提供查阅日志和分析结果的功能。
- 2) **有限审计查阅**。审计系统只提供对内容的读权限，应拒绝其他的用户访问审计系统。
- 3) **可选审计查阅**。在有限审计查阅的基础上限制查阅的范围。

6.4 安全审计与电子证据

5. 审计事件存储

审计事件的存储安全要求：

- 1) 受保护的审计踪迹存储。即要求存储系统对日志事件具有保护功能，防止未授权的修改和删除，并具有检测修改/删除的能力。
- 2) 审计数据的可用性保证。在审计存储系统遭受意外时，能防止或检测审计记录的修改；在存储介质存满或存储失败时，能确保记录不被破坏。
- 3) 防止审计数据丢失。在审计踪迹超过预定门限或记满时，应采取相应措施防止数据丢失。此措施可以是忽略可审计事件、只允许记录有特殊权限的事件、覆盖以前记录、停止工作等。



6.4 安全审计与电子证据

6.4.3 审计跟踪及实施

1. 审计跟踪的概念及意义

审计跟踪(Audit Trail)是系统活动的记录，这些记录可以**重构、评估、审查环境和活动的次序**，这些环境和活动是与同一项事务的开始到最后结束期间围绕或导致一项操作、一个过程或一个事件相关的。因此，审计跟踪可以**用于**：确定和保持系统活动中每个人的责任、重建事件、评估损失、检测系统问题区、提供有效的灾难恢复、阻止系统的不当使用等。

6.4 安全审计与电子证据

6.4.3 审计跟踪及实施

1. 审计跟踪的概念及意义

审计跟踪作为一种安全机制其目标：

- 1) 审查基于每个目标或每个用户的访问模式，并使用系统保护机制；
- 2) 发现试图绕过保护机制的外部人员和内部人员；
- 3) 发现用户从低等级到高等级的访问权限转移；
- 4) 制止用户企图绕过系统保护机制的尝试；
- 5) 作为另一种机制确保记录并发现用户企图绕过保护尝试，为损失控制提供足够信息。

6.4 安全审计与电子证据

安全审计跟踪机制的意义在于:经过事后的安全审计可以检测和调查安全漏洞。

1)不仅能够识别谁访问了系统（访问系统来源），还能指出系统正在被怎样使用（系统状态转移过程）。

2)可以确认网络攻击的情况，审计信息对于确认问题和攻击源很重要。用于检查网络犯罪。

3)系统事件的记录可更快速识别问题，并成为后续事故处理的重要依据。

4)通过对安全事件的不断收集与积累并且加以分析，有选择性地对其中的某些站点或用户进行审计跟踪，以提供发现可能产生破坏性行为的有力证据。

审计是系统安全策略的一个重要组成部分，贯穿整个系统运行过程中，覆盖不同的安全机制，为其他安全策略的改进和完善提供必要的信息。

6.4 安全审计与电子证据

2. 网络安全审计的实施

为了**确保**审计数据的**可用性和正确性**，审计数据需要受到保护。审计应根据需要(经常由**安全事件触发**)**定期审查、自动实时审查或两者兼顾**。系统管理人员应根据安全管理要求确定需要维护多长时间的审计数据，其中包括**系统内保存的和归档保存的数据**。与安全审计实施有关的问题包括：

1. 保护审计数据

应当**严格限制**在线访问审计日志。

审计数据保护常用**方法**：用数据签名和只读设备存储数据。

审计跟踪信息的保密性也应进行严格保护。

2. 审查审计数据

审计跟踪的**审查与分析**可分为事后检查、定期检查和实时检查**3种**。

3. 用审计分析的工具

1) 审计精选工具。 2) 趋势/差别探测工具。 3) 攻击特征探测工具。



6.4 安全审计与电子证据

6.4.4 电子证据概述

【案例 6-10】 随着信息网络技术的高速发展，网络犯罪的数量快速增长、手段不断翻新、危害更加深远。以电信网络诈骗、涉虚拟货币犯罪为代表的信息网络犯罪具备突出的链条性、跨地域性、涉众性特征，引发了犯罪管辖争议，增加了犯罪取证难度与证据审查难题。

6.4 安全审计与电子证据

6.4.4 电子证据概述

1. 电子证据的概念

电子数据是指基于计算机应用、通信和现代管理技术等电子化技术手段而形成的包括文字、图形符号、数字、字母等的客观资料。**电子数据必须经过查证属实才能成为电子数据证据**。对电子数据证据的其他表达方法类似的有“计算机证据”、“网络证据”、“数字证据”等。

电子证据即用于证明案件事实的电子数据。对于电子证据的定义，有两种是分为广义和狭义。





6.4 安全审计与电子证据

6.4.4 电子证据概述

1. 电子证据的概念

- 1) **广义的电子证据**是指以电子形式存在的，用作证据使用的一切材料及其派生物，或者说借助电子技术或电子设备而形成的一切证据。在概念中**突出了“电子形式”**（包括：**数字电子技术和模拟电子技术**），即由介质、磁性物、光学设备、计算机内存或类似设备生成、发送、接收、存储的任一信息的存在形式。
- 2) **狭义的电子证据**是数字化信息设备中存储、处理、传输、输出的数字化信息形式的证据。在概念中**突出“数字化”**，这是由于数字化信息技术已经及广泛的应用领域，而模拟信息技术使用范围越来越小，局限于原始信息的采集等有限的应用领域。

6.4 安全审计与电子证据

6.4.4 电子证据概述

2. 电子证据的特点

与传统证据一样，电子证据必须是可信、准确、完整、符合法律法规的，是法庭所能够接受的。同时，电子证据与传统证据不同，又具有以下特点：

- 1) 依赖性。电子证据的产生、存储和传输都依赖计算机技术、存储技术、网络技术等，离开了相应的技术设备，电子证据就无法正常保存和传输。
- 2) 多样性。电子证据综合了文本、图形、图像、动画、音频、视频等多种媒体信息。这种将多种表现形式融为一体的特点是电子证据所特有的。

6.4 安全审计与电子证据

6.4.4 电子证据概述

2. 电子证据的特点

3) **无形性**。电子证据是以二进制数据方式存在的，由“1”和“0”组成，大都以电、磁、光等形式存在于媒体介质之上，是肉眼无法直接观看的**无形体**，只有通过特定的设备和技术才能显示为有形内容。因此很难通过电子数据本身来确定其**制作主体**，而且对电子数据的**修改或删除**通常只在操作日志中留下记录，而从**电子数据本身根本看不出痕迹**。在对电子数据进行复制、分析和使用时，都应当对电子数据的真实性、完整性进行保护，比如通过电子签名和可信时间戳等方法进行保护。

6.4 安全审计与电子证据

6.4.4 电子证据概述

2. 电子证据的特点

4) **易破坏性与相对稳定性**。电子数据很容易被修改、篡改或删除，体现了电子证据的易破坏性;而通常情况下，不管是“删除”“清空回收站”还是“格式化”，这些操作都是针对其“文件名”的，保存在扇区上的文件本身数据并没有被修改，通过专业的软件**可以进行恢复**，这又体现了电子证据的相对稳定性。同时，电子证据的相对稳定性还表现在**可记录修改或篡改行为**上，如对入侵行为的记录、被修改文件文档属性信息的变化、硬盘的擦写痕迹、U 盘的使用记录等。因此，收集电子证据、审查电子证据等取证过程具有严格的程序要求。

6.4 安全审计与电子证据

6.4.4 电子证据概述

3. 电子证据的分类



对于电子证据的分类，主要以**电子数据为主体**按照不同的分类方法进行划分。

- 按照**收集措施**：静态电子数据与动态电子数据；
- 按照**电子数据生成的方式**：电子生成数据、电子存储数据与电子交互数据；
- 按照**电子数据的来源**：存储介质数据、电磁辐射数据与线路电子数据；
- 按照**电子数据是否加密**：加密电子数据与非加密数据；
- 按照**电子数据形成的环境**：封闭电子数据与网络电子数据；
- 按照**数据是否被删除、隐藏或隐写**：显性数据与隐性数据；
- 按照**电子数据存在时间**：易失性数据和非易失性数据等。

6.4 安全审计与电子证据

6.4.4 电子证据概述

【案例 6-11】 2018 年 9 月 3 日，最高人民法院审判委员会第 1747 次会议审议通过了《最高人民法院关于互联网法院审理案件若干问题的规定》，第 11 条第六款明确规定：当事人提交的电子数据，通过电子签名、可信时间戳、哈希值校验、区块链等证据收集、固定和防篡改的技术手段或者通过电子取证存证平台认证，能够证明其真实性的，互联网法院应当确认。这是我国首次以司法解释形式对电子签名、可信时间戳、哈希值校验及区块链等固证、存证手段进行法律确认，意味着电子数据的真实性效力取证方式得以确认。

6.4 安全审计与电子证据

6.4.5 电子数据取证技术

电子数据取证技术按照取证阶段的不同对其加以分类：

- 电子证据发现技术
- 电子证据保全技术
- 电子证据收集技术
- 电子证据检验技术
- 电子证据分析技术



6.4 安全审计与电子证据

6.4.5 电子数据取证技术

➤ 电子证据发现技术

电子证据的发现是整个取证工作的起始环节，主要的证据信息包括：计算机系统类型、硬件配置、运行环境、存储数据等；网络的端口服务、日志信息、拓扑结构等；相关设备比如打印机、扫描存储器中保留的案件相关线索和证据信息等。在此环节应用的具体技术有网络线索挖掘技术、数据解密技术、数据溯源技术、数据恢复技术、数据镜像技术、对比搜索技术、端口和漏洞扫描技术、日志分析技术等。

6.4 安全审计与电子证据

6.4.5 电子数据取证技术

➤ 电子证据保全技术

电子证据同任何其他证据一样，需要采取有效措施来**固定和保全**，以满足证据的**完整性和真实性**要求——即所收集到的证据自始至终都保持其最初的原始状态而没有被改动过。**电子证据保全是整个取证工作的难点之一**，主要是**采取**数据加密技术、数字摘要技术、时间戳技术和电子手印技术以及见证人签名生成证据监督链等。电子证据保全所应用的**具体**技术包括数据镜像复制技术、数据加密技术、数据审计技术、数字签名技术等。电子取证结果的**有效性**较多地依赖于**证据保全系统的科学性和有效性**，因此需要加强证据保全技术的标准化工作，制定更为详尽的技术和操作标准，保护证据的完整性。

6.4 安全审计与电子证据

6.4.5 电子数据取证技术

➤ 电子证据收集技术

电子证据的收集是整个取证工作中非常重要的环节，其本质是从众多未知和不确定性中找到确定性的东西，通过数据恢复、残缺数据提取、解码、解密、过滤等技术将**原始数据表达成可以理解的数据**。电子证据收集环节的**具体工作内容**有：全面备份源数据，如系统软硬件配置信息、日志记录、恢复和提取被删除数据、被毁坏数据和隐匿数据等；过滤出有必要分析的数据或者做软件残留的自动分析等；将隐匿的普通编码信息和元数码等解码，表达成为人们能够理解的形式。电子证据收集所应用的**具体技术**包括数据截取技术、数据扫描技术、数据恢复技术及数据复制技术等。



6.4 安全审计与电子证据

6.4.5 电子数据取证技术

➤ 电子证据检验技术

电子证据检验是对已经收集来的数据进行**检查、识别和提取**可能成为证据的电子数据的过程，是在电子证据收集、提取的基础上，对所提取的电子证据结合案件进行**合理解释**所涉及的相关技术。在收集电子证据环节也常被用来验证证据收集过程中可能出现的漏洞。电子证据检验所应用的**具体技术**包括数据挖掘技术、数据解密技术、数据搜索技术等。



6.4 安全审计与电子证据

6.4.5 电子数据取证技术

➤ 电子证据分析技术

电子证据分析可为查明案件事实真相提供充分的证据支持。证据分析**主要包括的内容**有:分析是否为多操作系统;分析有无隐藏分区;分析文件有无改动;分析系统是否联网,如已联网,具体是什么网络环境;分析上网日志、**IP**地址;分析有无远程控制和木马程序;分析不同证据之间的一致或矛盾的内因等。用于证据分析的**具体技术**包括日志分析技术、数据解密技术、数据挖掘技术、对比分析技术等。

6.4 安全审计与电子证据

6.4.5 电子数据取证技术

电子数据取证技术按照取证阶段的不同对其加以分类：

- 电子证据发现技术
- 电子证据保全技术
- 电子证据收集技术
- 电子证据检验技术
- 电子证据分析技术



📖讨论思考：

- 1) 安全审计的概念、目的、类型和结构是什么？
- 2) 系统日志分析的主要内容包括哪些？
- 3) 安全审计跟踪主要考虑哪几个方面问题？
- 4) 电子证据特点是什么？常用电子证据取证技术有哪些？



课后作业

练习与实践6

1 (5)

2

3 (1) (2) (3) (5)

作业提交：手写拍照或电子文档，保存为pdf格式，命名“学号-姓名”
班长/学委打包发我QQ（97251651）或者邮箱（jingkun@ahu.edu.cn）

6.5 本章小结

本章小结

身份认证和访问控制是网络安全的重要技术，也是网络安全登入的首要保障。本章概述了身份认证概念、作用、身份认证常用方式及身份认证机制。主要介绍了双因素安全令牌及认证系统、用户登入认证、认证授权管理。介绍了数字签名的概念、功能、种类、原理、应用、技术实现方法和过程。另外，介绍了访问控制的概念、模型、安全机制、安全策略、认证服务与访问控制系统、准入控制技术。其次，介绍了安全审计概念、系统日志审计、审计跟踪与实施。介绍了电子证据的概念、电子数据证据取证的基本技术等。最后，通过PDF文档的数字签名与访问控制实验，可促进对身份认证、数字签名及访问控制理论的理解，并与实践结合达到学以致用、融会贯通的目的。

6.6 实验6 配置IP访问控制列表

■ 6.6.1实验目的

实验目的主要包括：

- 1) 理解路由器上访问控制列表规则。
- 2) 掌握标准IP访问控制列表的配置方法。。

■ 6.6.2实验要求

■ 1. 实验设备

本实验需要使用1台安装有Cisco Packet Tracer软件的计算机。

■ 2. 注意事项

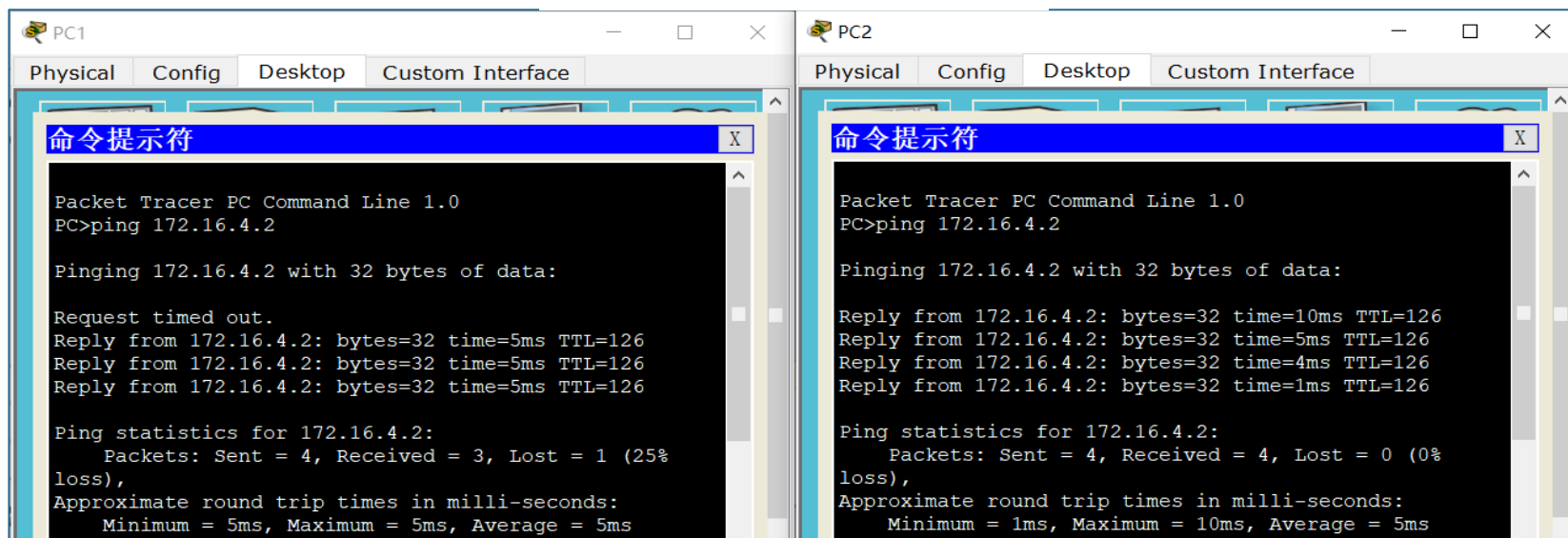
- 1) 预习准备。
- 2) 建议实验学时：2学时。

6.6 实验6 配置IP访问控制列表

6.6.3 实验内容及步骤

搭建如图6-15所示的拓扑环境，其中路由器Router1连接两个内部网，网段为172.16.1.0/24和172.16.2.0/24，路由器Router2连接公网一台安装有Web和FTP服务的服务器，在路由器上分别进行标准ACL访问控制及扩展ACL访问控制配置。使得PC1所在172.16.1.0网段能访问服务器，PC2不能访问服务器。

图6-15 未配置ACL时的测试状态



6.6 实验6 配置IP访问控制列表

6.6.3 实验内容及步骤

1. 标准ACL配置实验

1) 配置路由器Router 1和Router2的接口IP地址

```
Router>enable
```

```
Router#configure terminal
```

```
Router (config) #hostname Router1
```

```
Router1 (config) #interface fastethernet 0/0
```

```
Router1 (config-if) #ip address 172.16.1.1 255.255.255.0
```

```
Router1 (config-if) #no shutdown
```

```
Router1 (config-if) # interface fastethernet 1/0
```

```
Router1 (config-if) #ip address 172.16.2.1 255.255.255.0
```

```
Router1 (config-if) #no shutdown
```

```
Router1 (config-if) #interface serial 2/0
```

```
Router1 (config-if) #ip address 172.16.3.1 255.255.255.0
```

```
Router1 (config-if) #clock rate 64000
```

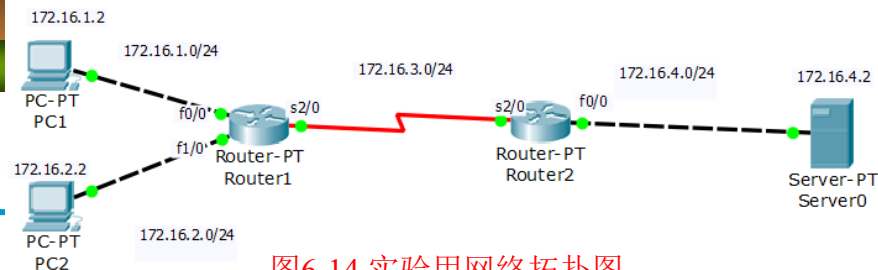
```
Router1 (config-if) #no shutdown
```

```
Router1 (config-if) #end
```

```
Router1#show ip interface brief
```

!观察接口状态

同理按照拓扑规划，配置Router2的IP地址信息、PC机和服务器的IP地址信息



6.6 实验6 配置IP访问控制列表

6.6.3 实验内容及步骤

1. 创建数字身份证书

2) 在Router1和Router2上配置路由信息。

Router1 (config) #ip route 172.16.4.0 255.255.255.0 172.16.3.2

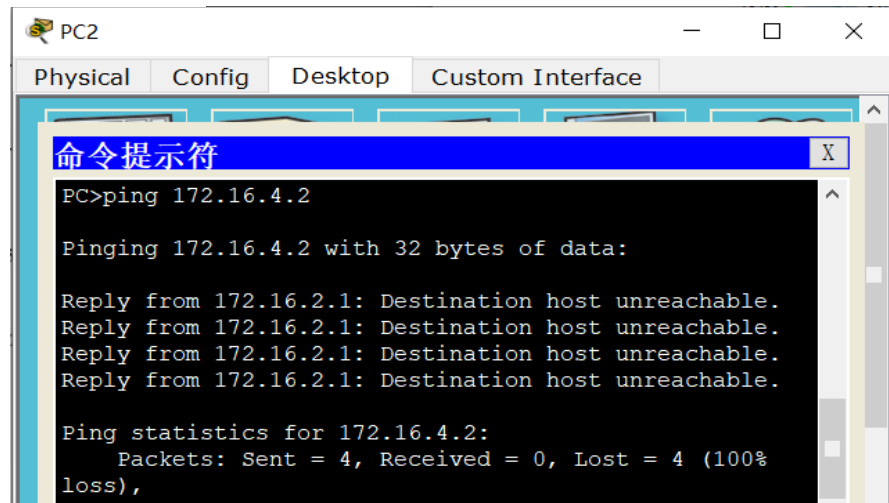
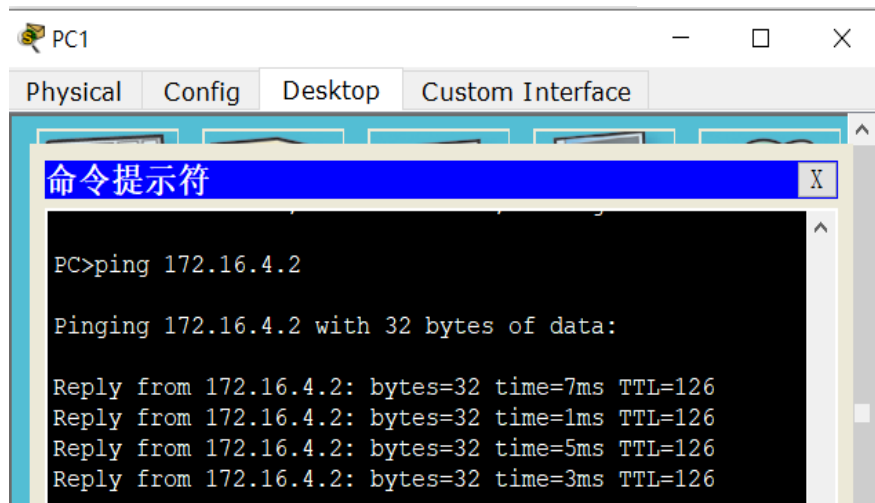
Router2 (config) #ip route 172.16.1.0 255.255.255.0 172.16.3.1

Router2 (config) #ip route 172.16.2.0 255.255.255.0 172.16.3.1

Router1# show ip route ! 查看路由表信息

此时配置主机IP后，两台主机分别ping服务器地址均可连通，如图6-16所示。

图6-16标准ACL配置后的测试状态



6.6 实验6 配置IP访问控制列表

6.6.3 实验内容及步骤

2. 扩展ACL配置实验

1) 按照前述标准ACL实验步骤1和2，完成拓扑图路由信息基础配置。

2) 配置扩展ACL，使PC1能访问服务器的www页面，但是不能ping通服务器，如图6-18所示。

```
Router1(config)#access-list 100 permit tcp host 172.16.1.2  
host 172.16.4.2 eq www
```

```
Router1(config)#access-list 100 deny icmp host 172.16.1.2  
host 172.16.4.2 echo
```

```
Router1(config)#int s2/0
```

```
Router1(config-if)#ip access-group 100 out
```

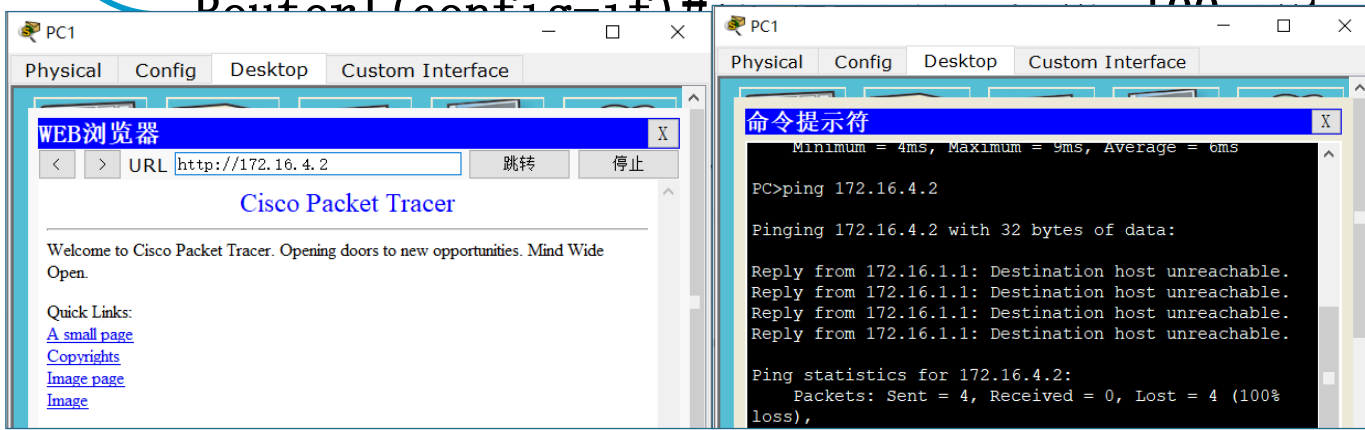


图6-17 扩展ACL配置后的测试状态

“十三五”国家重点出版规划
项目,上海市高校优秀教材奖

上海市高校精品课程特色教材
上海市高校优质在线课程教材

诚挚谢意!

网络安全技术及应用

国家智慧教育平台

国家智慧教育平台-上海精品/优质在线课程

(第5版,慕课微课版立体化)

